Федеральное государственное образовательное бюджетное учреждение высшего образования
«Финансовый университет при Правительстве Российской Федерации»
(Финансовый университет)

Колледж информатики и программирования

ОТЧЁТ

По учебной практике

Специальность 09.02.07 Информационные системы и программирование
(квалификация: Разработчик веб и мультимедийных приложений)
(код) (наименование)
Профессиональный модуль ПМ.09 Проектирование, разработка и оптимизация веб-приложений
(код) (наименование)

Междисциплинарный курс УП.09.01 Учебная практика
(код) (наименование)

Выполнил:
Студент 4 курса 4ИСИП-723 учебной группы
(номер) (номер)

Е.Д.Сидоров
(подпись) (инициалы, фамилия)

Проверил:
Руководитель практики от
Колледжа информатики и программирования

Преподаватель _____
(квалификационная
категория, звание, должность)

Москва 2026

Перечень работ, выполненных в ходе учебной практики

Практика выполнена индивидуально студентом Сидоровым Егором Денисовичем (группа 4ИСИП-723) по варианту № 6 «Мероприятия». Разработана веб-платформа «ОРБИТА» для поиска мероприятий и регистрации на них. Обязательное правило темы — число активных регистраций не превышает лимит участников — реализовано в серверной транзакции, в триггерах базы данных и в уникальном индексе. Приложение написано на Node.js 24 со встроенной СУБД SQLite без сторонних зависимостей. Исходный код, миграции, данные и материалы проверок находятся в папке «Сидоров_УП09_Мероприятия» (структура 01_Проект … 07_Документы по маршруту выполнения).

Все приведённые результаты (тесты, замеры, снимки экранов) получены на реально работающем приложении 07.11.2026. Действия, которые не выполнялись, отмечены в тексте как не выполненные.

Таблица №1 – Состав работ по теме «Мероприятия» (занятия практики, 36 академических часов)

Тема отчёта	Занятия	Основные материалы
1. Требования и проектирование	1–2	ТЗ, карта страниц, прототипы
2. База данных	3	Схема, миграции, учебные данные
3. Аутентификация, роли и защита	6	Вход, права, матрица доступа
4. Реализация: каталог, кабинет, панель организатора	4–5, 7	Страницы, CRUD, поиск и фильтры
5. Правило темы: регистрация и лимит	7	Транзакция, триггеры, тесты на одновременность
6. Тестирование и безопасность	8	60 автотестов, журнал дефектов, чек-лист
7. Статистика, оптимизация, SEO, восстановление	9–12	Замеры, журнал обращений, SEO, резервная копия

Тема 1: Анализ предметной области и проектирование платформы мероприятий.

Цель: описать проблему и назначение платформы, определить роли, составить проверяемые требования и сценарии, принять решение по этической ситуации, спроектировать карту страниц и прототипы.

Предметная область: организация мероприятий и регистрация участников (IT-конференции, лекции, форумы, выставки, спорт, культура).

Ход работы:

1. Описать проблему, пользователей и границы проекта:

Информация о мероприятиях разбросана по афишам и чатам, а запись ведётся в таблицах: легко записать людей больше, чем есть мест, или внести одного человека дважды. Платформа собирает события в единый каталог, принимает регистрации и гарантирует соблюдение лимита. Из границ исключены онлайн-оплата, листы ожидания, рассылки и загрузка файлов. Роли и возможности приведены в таблице №2.

Таблица №2 – Роли пользователей платформы

Роль	Возможности
Гость	Просмотр каталога, карточек и категорий, регистрация аккаунта, форма контактов
Участник (user)	Запись на мероприятия и отмена, личный кабинет, история посещений
Организатор (organizer)	Создание и правка своих мероприятий, список участников, отметка присутствия, отмена регистраций на своих событиях
Администратор (admin)	Управление любыми мероприятиями, статистика обращений, сообщения из формы контактов

2. Сформулировать требования и критерии приёмки:

Таблица №3 – Функциональные требования

Код	Требуемое действие	Критерий приёмки
ФТ-01	Каталог: поиск по названию, фильтр по категории и датам, сортировка, страницы	Результат соответствует запросу; условия сохраняются при смене страницы; пустой результат объяснён
ФТ-02	Страница мероприятия: данные, занято/свободно/лимит	Данные читаются из БД; несуществующий номер — 404
ФТ-03	Регистрация и отмена с лимитом участников	Активных регистраций не больше лимита (в том числе при одновременных запросах); повтор отклоняется; отмена освобождает место
ФТ-04	Аккаунты: регистрация, вход, выход, роли	Пароль — хеш; логин уникален; после выхода закрытые действия недоступны
ФТ-05	Личный кабинет: предстоящие, история, отменённые	Видны только свои регистрации; чужую отменить нельзя (403)

Код	Требуемое действие	Критерий приёмки
ФТ-06	Панель организатора: создание, правка, удаление, список участников, свободные места	Недопустимые данные отклоняются с сохранением введённого; управление только своими событиями
ФТ-07	Защита данных	CSRF-токены, экранирование, параметризованные запросы, права на сервере
ФТ-08	Информационные страницы, SEO, журнал обращений	title/description/canonical, sitemap, robots; статистика для администратора

3. Описать пользовательские сценарии:

Таблица №4 – Пользовательские сценарии

№	Исходное состояние	Действия	Результат
С1	Участник вошёл; на мероприятии осталось одно место	Нажимает «Зарегистрироваться»	Регистрация создана, сообщение «осталось: 0»; следующему пользователю кнопка недоступна
С2	Организатор вошёл	Создаёт мероприятие с лимитом 3 и публикует; три участника записываются	В панели «занято 3, свободно 0»; четвёртая регистрация отклонена; отмена освобождает место
С3	Участник знает номер чужой регистрации	Отправляет запрос отмены напрямую, без кнопок	Ответ 403, регистрация осталась активной

4. Принять решение по этической ситуации:

Ситуация: участник проекта предлагает вознаграждение за изменение учебного результата и исключение найденной ошибки из протокола проверки. Решение: отказаться, результат и протокол не менять. Порядок действий: письменно отказаться; сохранить исходный протокол и историю изменений в репозитории как подтверждение достоверности; сообщить руководителю практики и действовать по правилам колледжа об академической честности; исправить ошибку и пройти повторную проверку; указать авторство (чужие фрагменты — со ссылкой на источник). Обоснование: изменение результата — фальсификация; для платформы с правилом лимита журнал дефектов и протоколы доказывают, что защита работает. Полный текст — в файле «Личный_план_бюджет_этика_источники».

5. Составить личный план, условный бюджет и перечень источников:

Сравнение вариантов поддержки проекта при стоимости часа 500 руб.: вариант А — 0 × 12 + 24 × 500 = 12 000 руб. в год; вариант Б — 300 × 12 + 6 × 500 = 6 600 руб. в год. Выбран вариант Б: он дешевле на 5 400 руб., а денежная часть 3 600 руб. покрывается остатком условного годового бюджета 12 000 руб. (доход 540 000 − расходы 528 000). План, расчёт и источники

приведены в файле «Личный_план_бюджет_этика_источники» (папка 07_Документы).

6. Спроектировать карту страниц и прототипы:

Карта включает 12 групп страниц: главная, каталог, мероприятие, категории и категория, о платформе, контакты, вход и регистрация, кабинет, мои регистрации, панель организатора, создание и редактирование, участники и администрирование. Доступ проверяется сервером (таблица № 5). Прототипы списка, карточки, формы и входа с состояниями «пустой список», «ошибка ввода», «нет записи» — в файле «Прототипы» (листинг №1).

Таблица №5 – Карта страниц и доступ (фрагмент; полная матрица — в «Карта_страниц.md»)

Страница	**Адрес**	**Кто имеет доступ**
Каталог	/events	Все
Мероприятие	/events/:id	Все (черновики — только владельцу и админу)
Мои регистрации	/account/registrations	Вошедшие; только свои записи
Панель организатора	/organizer	Организатор (свои события), админ (все)
Участники мероприятия	/organizer/events/:id/registrations	Владелец события, админ
Администрирование	/admin	Только админ

Листинг №1 – схема прототипа карточки мероприятия

```
КАТЕГОРИЯ · [метка состояния]          [фото]
Название мероприятия
Краткое описание
[дата и время | место | организатор]   ┌ РЕГИСТРАЦИЯ ──────────┐
О мероприятии (описание, программа)    │ Цена  ──▒ 11 из 30    │
Похожие события                        │ занято | свободно | лимит │
                                       │ [Зарегистрироваться]  │
                                       └───────────────────────┘
```

Вывод: определены роли, составлены восемь требований с критериями и три сценария, принято решение по этической ситуации, подготовлены карта страниц и прототипы; требования реализованы и проверены в следующих темах.

Тема 2: Проектирование базы данных.

Цель: выделить предметные сущности, определить типы полей, ограничения и политику удаления, создать схему миграциями, загрузить учебные данные и проверить ограничения целостности.

Предметная область: мероприятия, категории и регистрации участников.

Ход работы:

1. Выделить сущности и связи:

Предметных сущностей три: категории (categories), мероприятия (events) и регистрации (registrations); они связаны с учётными записями (организатор, участник). Служебные таблицы: sessions (сеансы и CSRF-токены), messages (форма контактов), access_log (журнал обращений). Схема связей показана на рисунке №1, описание таблиц — в таблице №6.

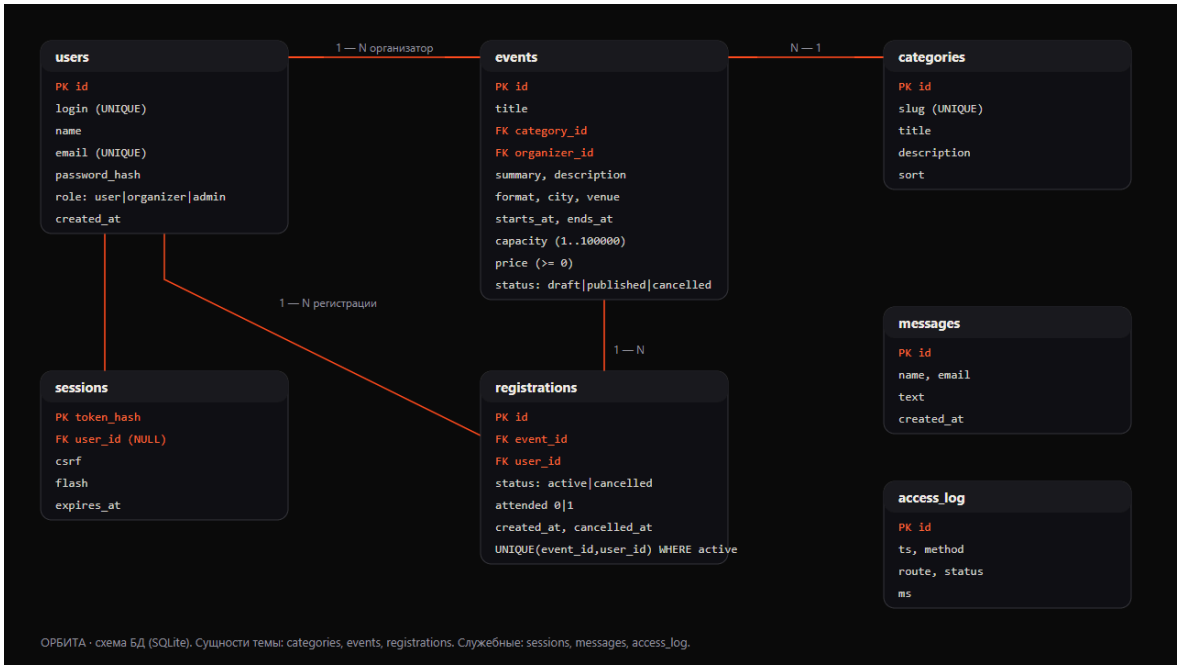


Рисунок №1 – Схема связей таблиц базы данных «ОРБИТА»

Таблица №6 – Сущности базы данных

Таблица	Назначение	Ключевые связи
categories	Шесть категорий мероприятий	—
events	Мероприятия: описание, время, место, лимит, цена, статус	category_id → categories; organizer_id → users
registrations	Регистрации: статус active/cancelled, присутствие	event_id → events; user_id → users
users	Учётные записи: логин, хеш пароля, роль	—
sessions, messages, access_log	Сеансы, сообщения, журнал обращений	sessions.user_id → users

2. Определить типы полей, ограничения и политику удаления:

Статусы, роли и формат ограничены перечислениями (CHECK); лимит — от 1 до 100 000; окончание позже начала; цена неотрицательна. Логин и e-mail уникальны без учёта регистра. Ключевое ограничение темы — частичный уникальный индекс «одна активная регистрация пользователя на мероприятие» и триггеры, не допускающие превышения лимита. Политика удаления: регистрации удаляются вместе с мероприятием или пользователем (CASCADE); категорию и организатора с событиями удалить нельзя (RESTRICT); отмена регистрации сохраняет строку со статусом cancelled, поэтому место освобождается, а история остаётся. Фрагмент миграции приведён в листинге №2.

Листинг №2 – фрагмент миграции 001_init.sql: таблица registrations, индекс и триггер лимита

```
CREATE TABLE registrations (
  id           INTEGER PRIMARY KEY AUTOINCREMENT,
  event_id     INTEGER NOT NULL REFERENCES events(id) ON DELETE CASCADE,
  user_id      INTEGER NOT NULL REFERENCES users(id)  ON DELETE CASCADE,
  status       TEXT NOT NULL DEFAULT 'active' CHECK (status IN ('active',
'cancelled')),
  attended     INTEGER NOT NULL DEFAULT 0 CHECK (attended IN (0, 1)),
  created_at   TEXT NOT NULL DEFAULT (datetime('now')),
  cancelled_at TEXT
);

-- Один пользователь — одна АКТИВНАЯ регистрация на мероприятие (после
отмены можно записаться снова).
CREATE UNIQUE INDEX ux_registrations_active ON registrations (event_id,
user_id) WHERE status = 'active';

CREATE TRIGGER trg_reg_insert BEFORE INSERT ON registrations WHEN NEW.status
= 'active'
BEGIN
  SELECT RAISE(ABORT, 'EVENT_CLOSED')
   WHERE (SELECT status FROM events WHERE id = NEW.event_id) IS NOT
'published';
  SELECT RAISE(ABORT, 'EVENT_FULL')
   WHERE (SELECT count(*) FROM registrations WHERE event_id = NEW.event_id
AND status = 'active')
         >= (SELECT capacity FROM events WHERE id = NEW.event_id);
END;
```

3. Создать схему миграциями и загрузить учебные данные:

Миграции применяются скриптом scripts/db.js (npm run db:reset); данные формируются генератором src/seed.js и целиком вымышлены. Состав приведён в таблице №7.

Таблица №7 – Состав учебных данных

Таблица	Записей	Комментарий
users	26	1 администратор, 3 организатора, 22 участника
categories	6	IT, образование, бизнес, выставки, спорт, культура
events	63	60 опубликованных (предстоящие и прошедшие), 2 черновика, 1 отменённое; несколько мероприятий заполнены полностью
registrations	727	активные и отменённые; для прошедших событий отмечено присутствие
Итого	822	при минимуме 20 записей по заданию

4. Проверить ограничения целостности:

Недопустимые данные вставлялись напрямую в БД, минуя приложение (автотесты A1–A10, таблица №8).

Таблица №8 – Проверка ограничений базы данных

Проверка	Фактический результат
Дубль активной регистрации отклонён индексом UNIQUE	Выполнено: ограничение сработало, как ожидалось
Превышение лимита отклонено триггером EVENT_FULL	Выполнено: ограничение сработало, как ожидалось
Запись на черновик отклонена (EVENT_CLOSED)	Выполнено: ограничение сработало, как ожидалось
Лимит нельзя уменьшить ниже числа активных регистраций	Выполнено: ограничение сработало, как ожидалось
Неверная ссылка (несуществующий пользователь) — FOREIGN KEY	Выполнено: ограничение сработало, как ожидалось
Отрицательная цена отклонена ограничением CHECK	Выполнено: ограничение сработало, как ожидалось
Мероприятие нельзя создать от имени обычного пользователя	Выполнено: ограничение сработало, как ожидалось
Дубль логина без учёта регистра отклонён	Выполнено: ограничение сработало, как ожидалось
Каскад: при удалении мероприятия удаляются его регистрации	Выполнено: ограничение сработало, как ожидалось
После отмены повторная запись допустима, занято мест — 1	Выполнено: ограничение сработало, как ожидалось
Одновременные процессы (4×20 вставок на 10 мест): занято ровно 10	Выполнено: ограничение сработало, как ожидалось

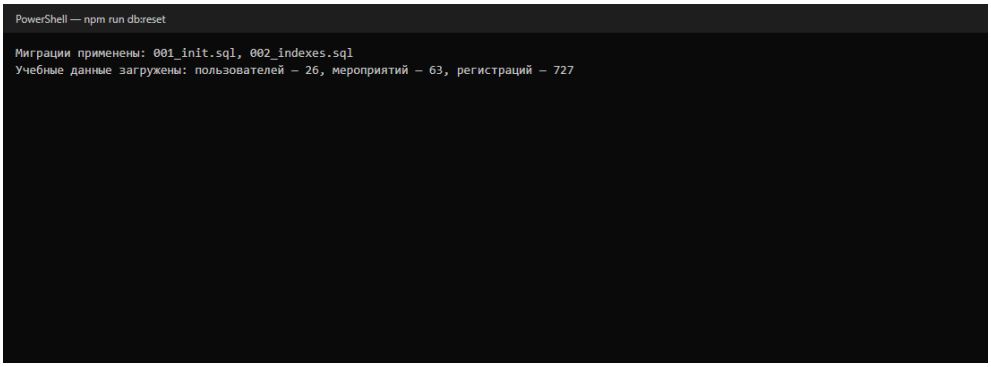


Рисунок №2 – Создание БД миграциями и загрузка учебных данных (npm run db:reset)

5. Воспроизвести создание БД в отдельной пустой базе:

Каждый запуск автотестов создаёт новую временную БД, применяет миграции и загружает данные; проверка восстановления копируется в отдельную БД (тема 7). Рабочая БД не удаляется. Копии миграций сохранены в папке 02_Данные.

Вывод: спроектированы три предметные сущности со связями, перечислениями и политикой удаления; загружено 822 учебные записи; 11 из 11 проверок подтвердили, что недопустимые данные, дубли и превышение лимита отклоняются самой СУБД.

Тема 3: Аутентификация, роли и права доступа.

Цель: реализовать вход и выход, хранение паролей в виде хешей, серверные сеансы, защиту от подделки запросов и разграничение доступа по ролям и владельцу записи.

Предметная область: учётные записи участников, организаторов и администратора.

Ход работы:

1. Реализовать регистрацию, вход и хранение паролей:

При регистрации проверяются имя, формат логина, сложность пароля (не менее 8 символов, буквы и цифры) и уникальность логина и e-mail без учёта регистра. Пароль хранится в виде хеша scrypt с индивидуальной солью; сообщение об ошибке входа одинаково для неизвестного логина и неверного пароля, а проверка хеша выполняется всегда. После пяти неудачных попыток вход блокируется на 10 минут (листинг №3, рисунок №3).

Листинг №3 – хеширование и проверка пароля (src/auth.js)

```
export function hashPassword(pw) {
  const salt = crypto.randomBytes(16).toString('hex');
  return `scrypt$${salt}$${crypto.scryptSync(pw, salt,
64).toString('hex')}`;
}

export function verifyPassword(pw, stored) {
  const [alg, salt, hash] = String(stored).split('$');
  if (alg !== 'scrypt' || !salt || !hash) return false;
  const a = Buffer.from(hash, 'hex');
  const b = crypto.scryptSync(String(pw), salt, 64);
  return a.length === b.length && crypto.timingSafeEqual(a, b);
}
```

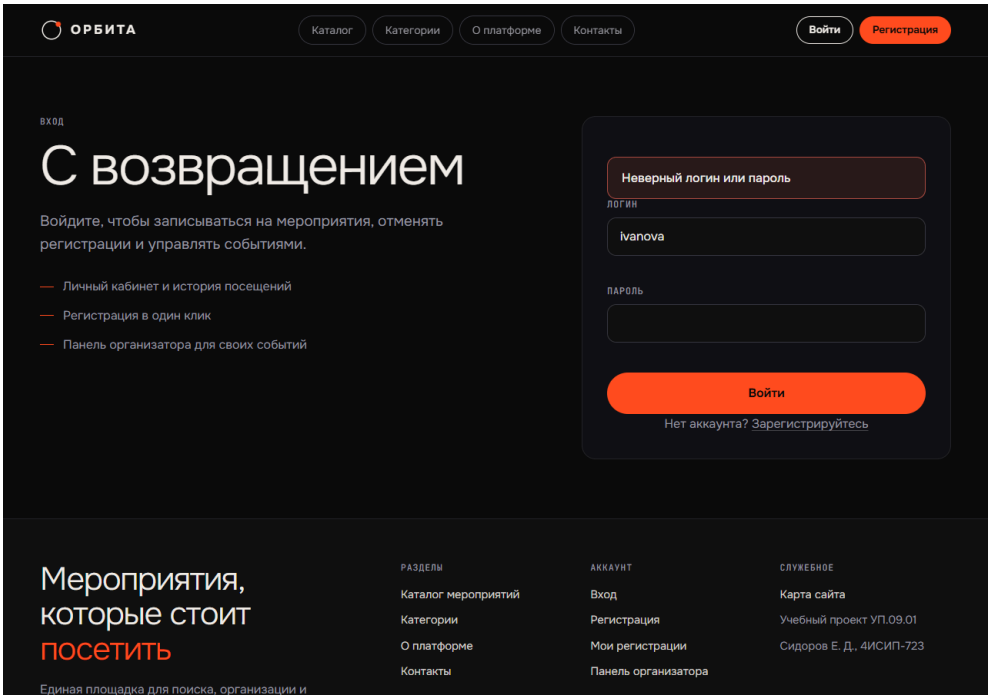


Рисунок №3 – Сообщение об ошибке входа (неверный пароль)

2. Организовать сеансы и защиту от CSRF:

Идентификатор сеанса — случайное значение в cookie с атрибутами HttpOnly и SameSite=Lax; в БД хранится только его SHA-256. При входе идентификатор заменяется (защита от фиксации), при выходе сеанс удаляется на сервере. Каждый POST-запрос должен содержать токен сеанса, который сравнивается за постоянное время (листинг №4).

Листинг №4 – создание сеанса и проверка CSRF-токена (src/auth.js)

```
export function createSession(db, userId = null) {
  const token = crypto.randomBytes(32).toString('base64url');
  const csrf = crypto.randomBytes(24).toString('base64url');
  db.run('INSERT INTO sessions(token_hash, user_id, csrf, expires_at) VALUES
(?,?,?,?)',
    sha(token), userId, csrf, Date.now() + config.sessionTtl);
  return { token, csrf, user_id: userId };
}

export function checkCsrf(session, given) {
  if (!session || !given) return false;
  const a = Buffer.from(session.csrf);
  const b = Buffer.from(String(given));
  return a.length === b.length && crypto.timingSafeEqual(a, b);
}
```

3. Задать роли и матрицу прав:

Определены роли: участник, организатор, администратор. Права проверяются на сервере: общие правила — в описании маршрута (roles/auth), принадлежность записи — в модуле правил (таблица №9).

Таблица №9 – Матрица прав доступа (✓ разрешено, ✕ запрещено)

Действие	Гость	Участник	Организатор	Админ
Каталог, карточка мероприятия	✓	✓	✓	✓
Записаться на мероприятие	✕ (401)	✓	✓	✓
Отменить регистрацию	✕	свою	свою и на своих событиях	любую
Кабинет и «Мои регистрации»	✕	свои	свои	свои
Панель организатора	✕	✕ (403)	свои события	все события
Участники мероприятия, CSV, отметка присутствия	✕	✕	только свои	все
Администрирование и статистика	✕	✕	✕	✓

4. Реализовать серверные проверки доступа:

Листинг №5 – проверка роли и принадлежности регистрации (src/server.js, src/rules.js)

```
  const requireUser = (ctx) => { if (!ctx.user) throw new HttpError(401,
'Войдите в аккаунт'); return ctx.user; };
  const requireRole = (ctx, roles) => {
    const u = requireUser(ctx);
    if (!roles.includes(u.role)) throw new HttpError(403, 'Недостаточно прав
для этого действия');
    return u;
  };

export function cancelRegistration(db, actor, regId) {
  const reg = db.get(`SELECT r.*, e.organizer_id, e.starts_at, e.title FROM
registrations r JOIN events e ON e.id = r.event_id WHERE r.id = ?`,
Number(regId) || 0);
  if (!reg) throw new HttpError(404, 'Регистрация не найдена');
  const own = reg.user_id === actor.id;
  const manager = actor.role === 'admin' || reg.organizer_id === actor.id;
  if (!own && !manager) throw new HttpError(403, 'Это не ваша регистрация');
  if (reg.status !== 'active') throw new HttpError(409, 'Регистрация уже
отменена');
  if (own && !manager && reg.starts_at <= localIso()) throw new
HttpError(409, 'Мероприятие уже началось: отмена невозможна');
  db.run("UPDATE registrations SET status = 'cancelled', cancelled_at =
datetime('now') WHERE id = ?", reg.id);
  return reg;
}
```

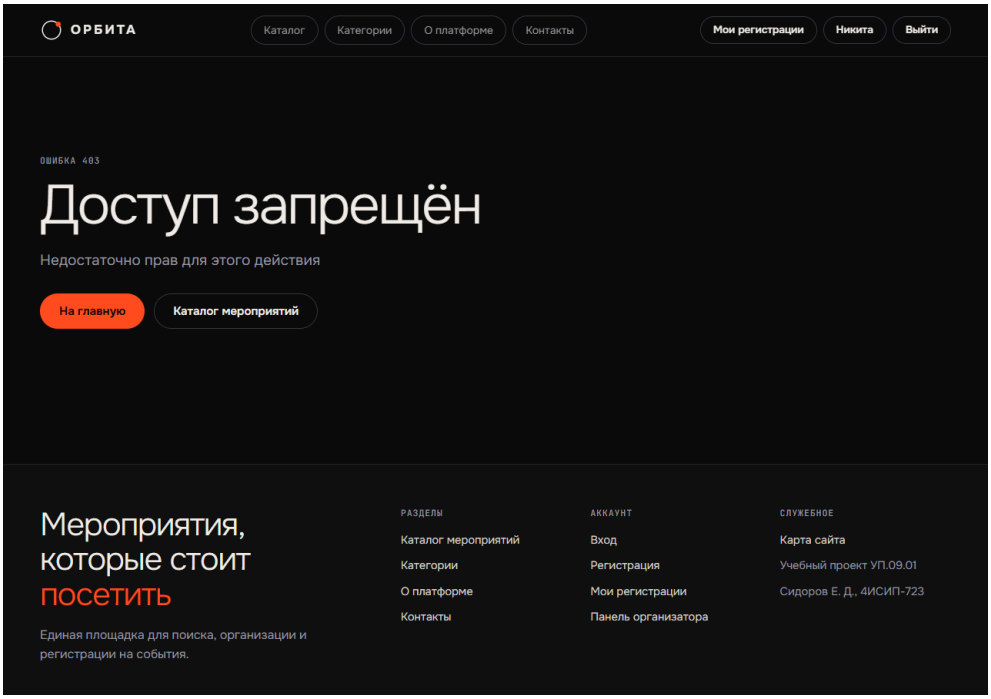


Рисунок №4 – Попытка участника открыть панель организатора: ошибка 403

5. Проверить вход, выход и разграничение доступа:

Таблица №10 – Проверка входа и прав доступа

Проверка	**Фактический результат**
Анонимный доступ к панели организатора — 401, к кабинету — 401	Выполнено
Обычный пользователь не попадает в панель организатора — 403	Выполнено
Организатор не может изменить и удалить чужое мероприятие — 403	Выполнено
Список участников чужого мероприятия и CSV недоступны — 403	Выполнено
Раздел администратора: админ — 200, организатор — 403	Выполнено
После выхода старый сеанс не даёт доступа — 401	Выполнено
Неверный пароль — 401 без выдачи сеанса пользователя	Выполнено
Шесть неверных входов подряд — блокировка 429, верный пароль тоже отклоняется	Выполнено
Идентификатор сеанса меняется при входе, cookie HttpOnly + SameSite	Выполнено
Перенаправление после входа только на внутренние адреса	Выполнено
Пароли хранятся только в виде хеша scrypt	Выполнено

Вывод: реализованы вход, выход и три роли с проверкой прав на сервере; пароли хранятся хешем, сеансы защищены; 11 из 11 проверок входа и доступа выполнены, прямые запросы без кнопок отклоняются.

Тема 4: Реализация платформы: каталог, кабинет и панель организатора.

Цель: реализовать многостраничный адаптивный сайт на базе данных: каталог с поиском и фильтрами, карточку мероприятия, личный кабинет и панель организатора.

Предметная область: веб-приложение для мероприятий.

Ход работы:

1. Определить технологии и структуру проекта:

Приложение написано на Node.js 24.19 со встроенными модулями http и node:sqlite (SQLite 3.53); страницы формируются на сервере безопасным шаблонизатором, стили — собственная дизайн-система на CSS, шрифты Onest и JetBrains Mono подключены локально, фото — Unsplash (свободная лицензия). Сторонних npm-зависимостей нет. Предметная логика собрана в одном модуле и не дублируется в маршрутах; интерфейс строится из общих компонентов (таблица №11).

Таблица №11 – Структура проекта и назначение файлов

Файл	Назначение
src/server.js	Контекст запроса, сеансы, CSRF, права, ошибки, журнал обращений
src/rules.js	Регистрация и отмена, лимит, каталог, проверка форм, статистика
src/auth.js, src/db.js, src/http.js	Пароли и сеансы; БД и миграции; маршрутизатор, ответы, статические файлы
src/ui.js, src/html.js	Общие компоненты (шапка, карточка, поля форм, пагинация), экранирование
src/routes/*.js	Страницы: public, auth, account, organizer (+ admin)
migrations/, scripts/	Схема БД; db, test, bench, backup, traffic, seo-check
public/	CSS, JS, шрифты, фото

2. Реализовать каталог и карточку мероприятия:

Каталог читает данные из БД, поддерживает поиск по названию без учёта регистра (в том числе для кириллицы), фильтры по категории, датам, периоду, наличию мест и цене, пять вариантов сортировки и постраничный вывод по 9 карточек; условия сохраняются в ссылках страниц. Карточка показывает дату, место, организатора, занято/свободно/лимит и состояние регистрации (рисунки №5–№8, №9).

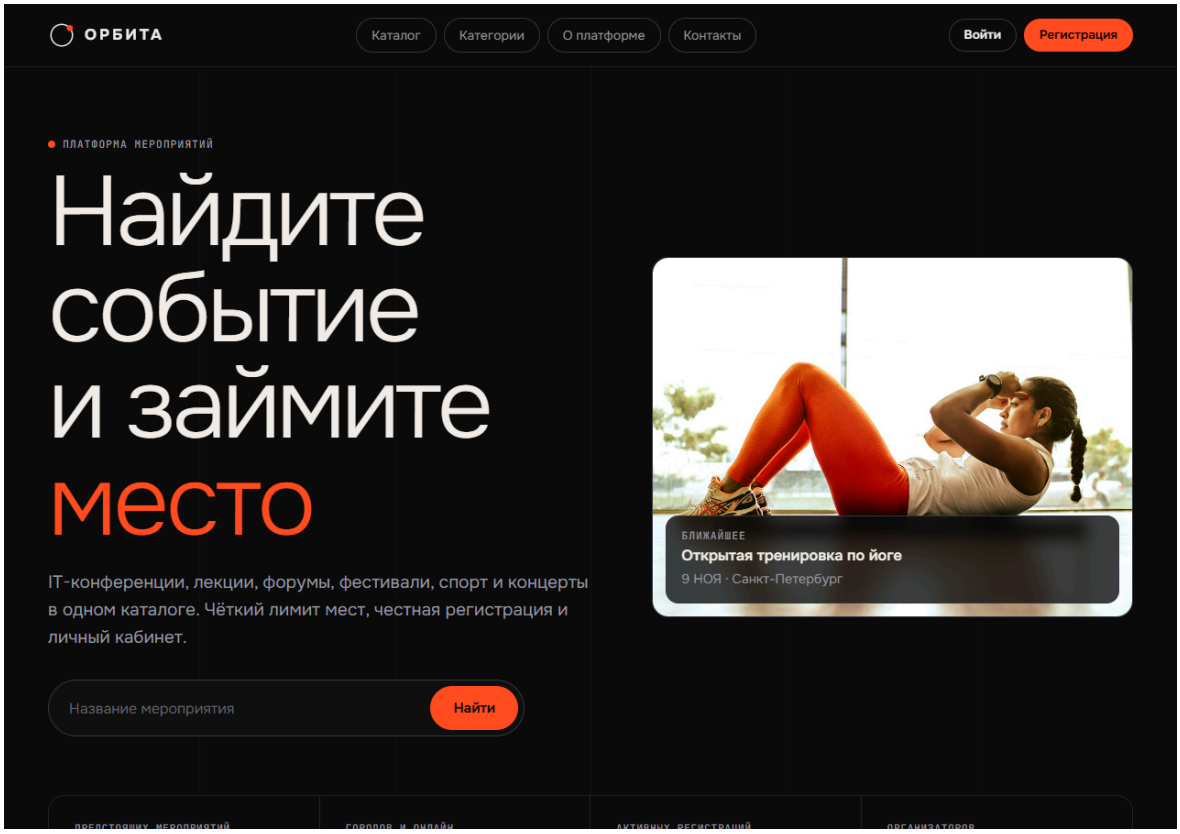


Рисунок №5 – Главная страница (1280 px)

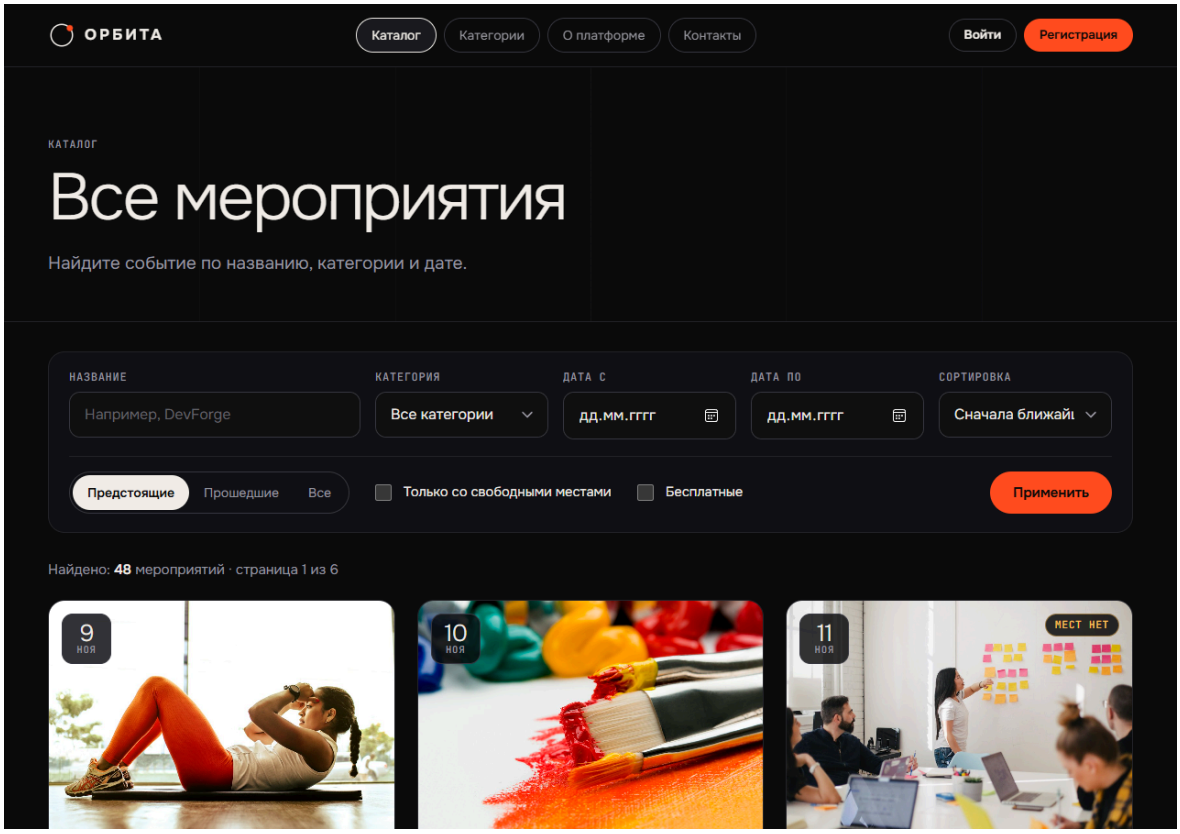


Рисунок №6 – Каталог мероприятий: поиск, фильтры, сортировка

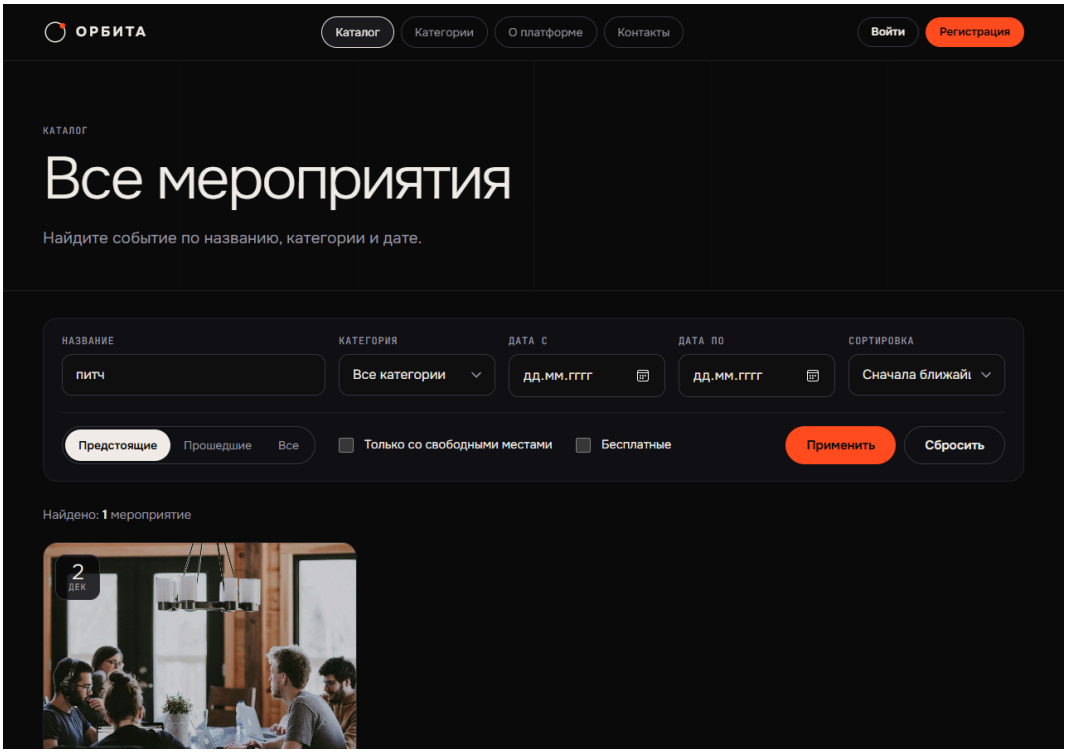


Рисунок №7 – Поиск по названию «питч» (без учёта регистра)

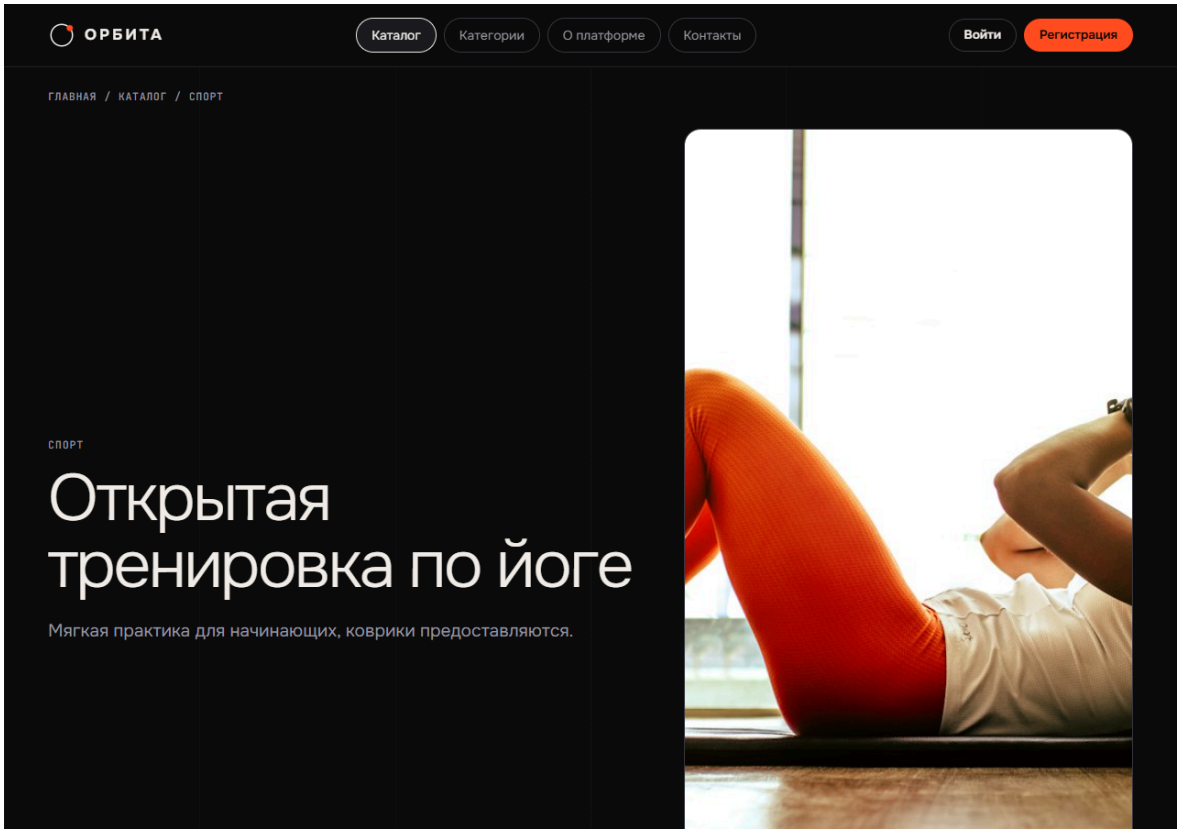


Рисунок №8 – Страница мероприятия с панелью регистрации

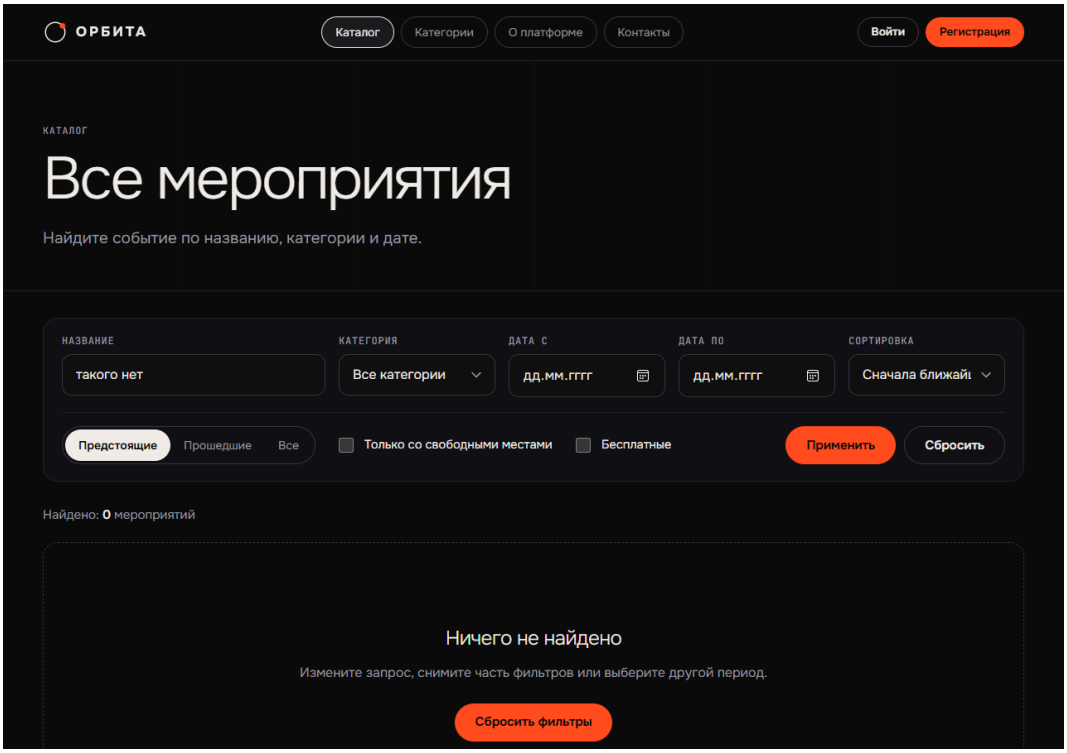


Рисунок №9 – Пустой результат поиска

3. Реализовать личный кабинет участника:

Кабинет показывает статистику и ближайшие события; «Мои регистрации» разделены на предстоящие, историю посещений и отменённые (рисунки №10–№12).

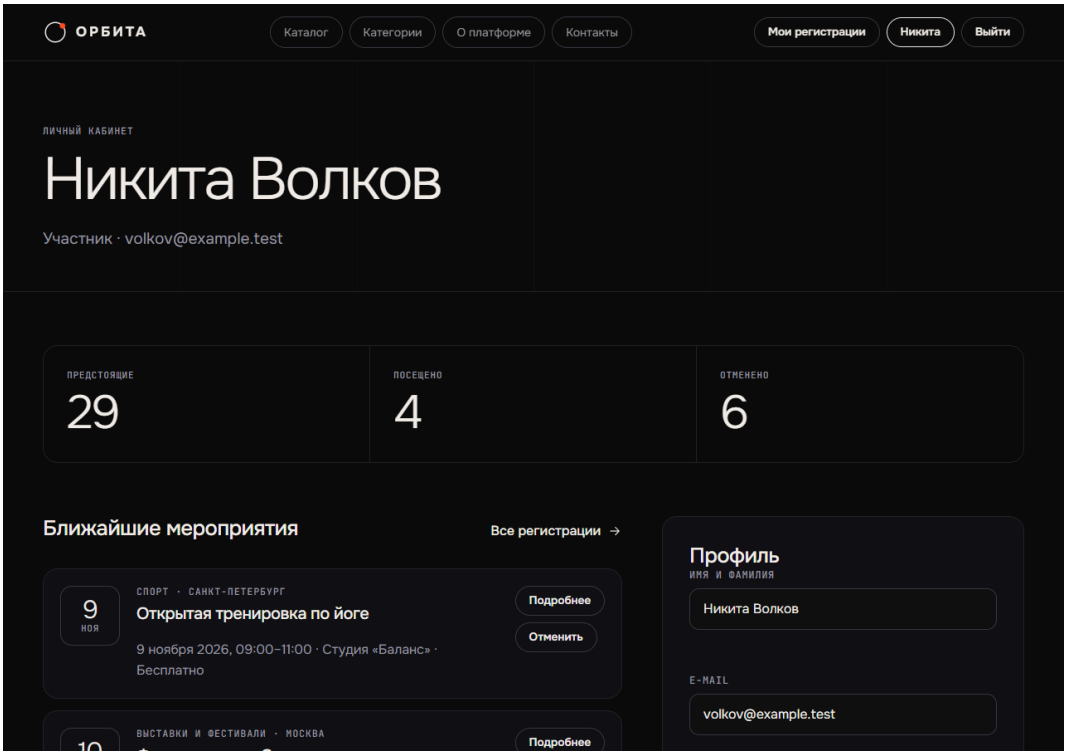


Рисунок №10 – Личный кабинет участника

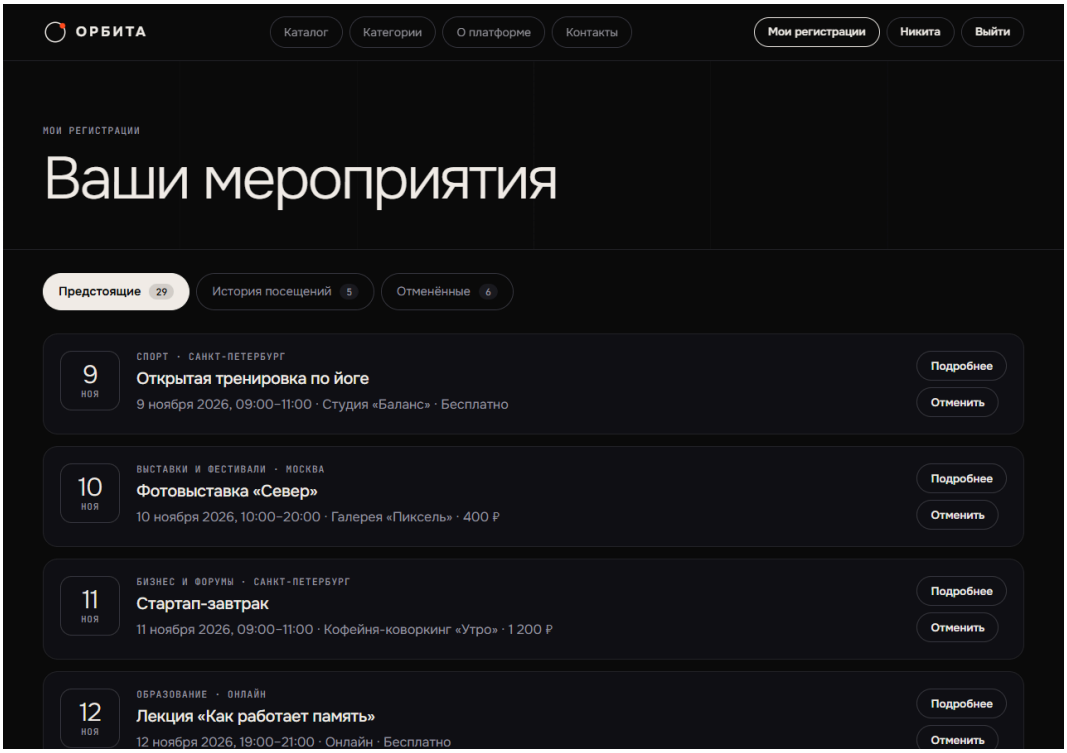


Рисунок №11 – Мои регистрации: предстоящие мероприятия и отмена

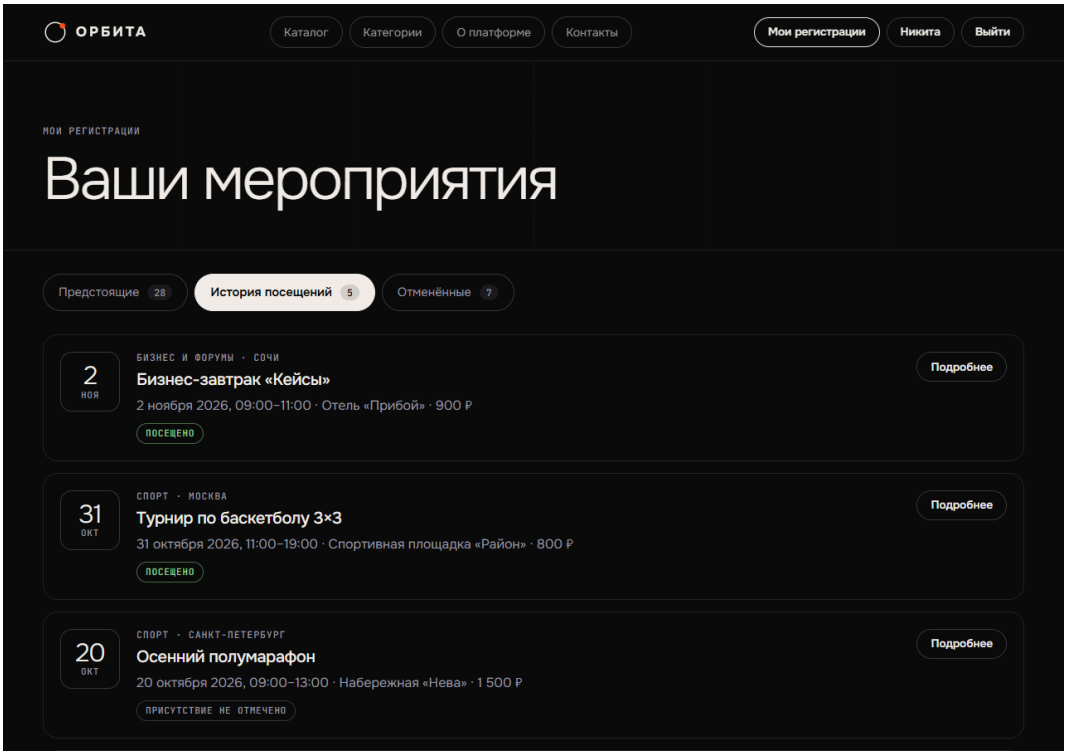


Рисунок №12 – История посещений

4. Реализовать панель организатора:

Организатор видит свои мероприятия с заполненностью и свободными местами, создаёт и редактирует события (серверная проверка, при ошибке значения сохраняются), публикует, отменяет, удаляет события без активных

регистраций, просматривает участников, отмечает присутствие и выгружает CSV (рисунки №13–№17).

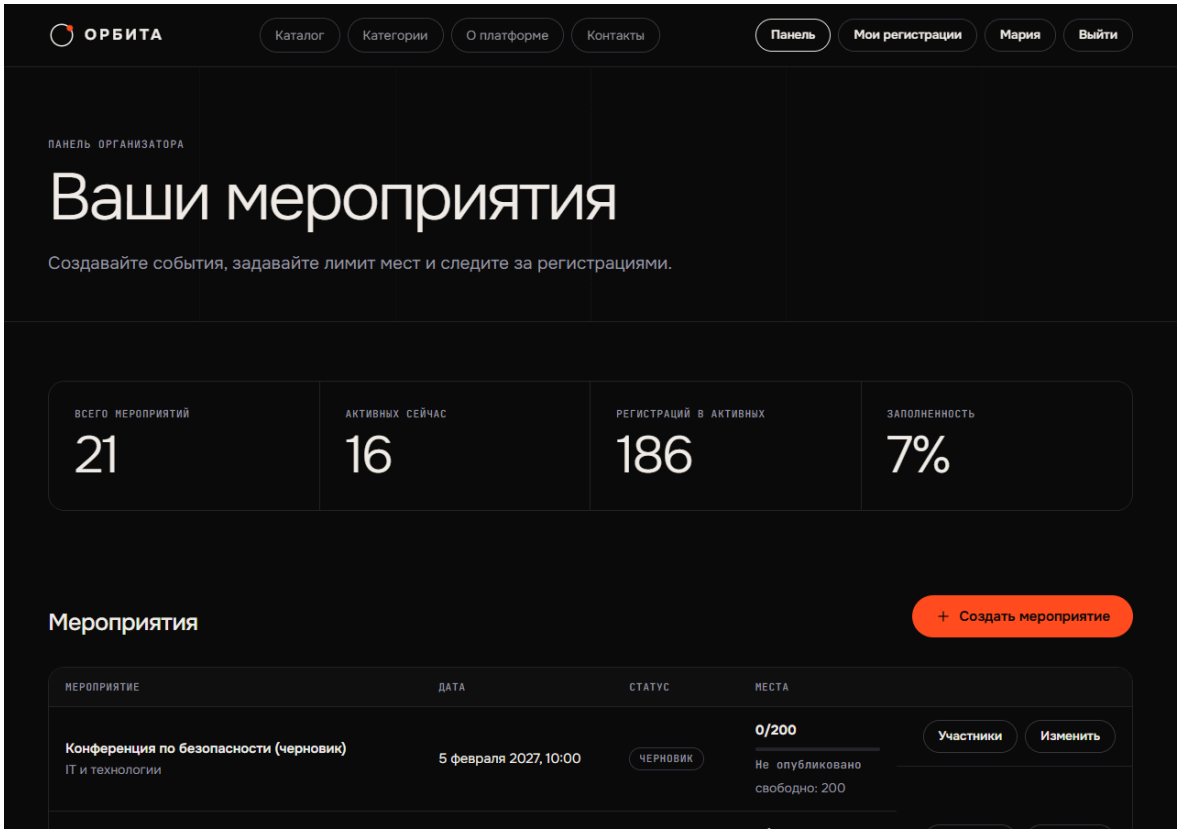


Рисунок №13 – Панель организатора

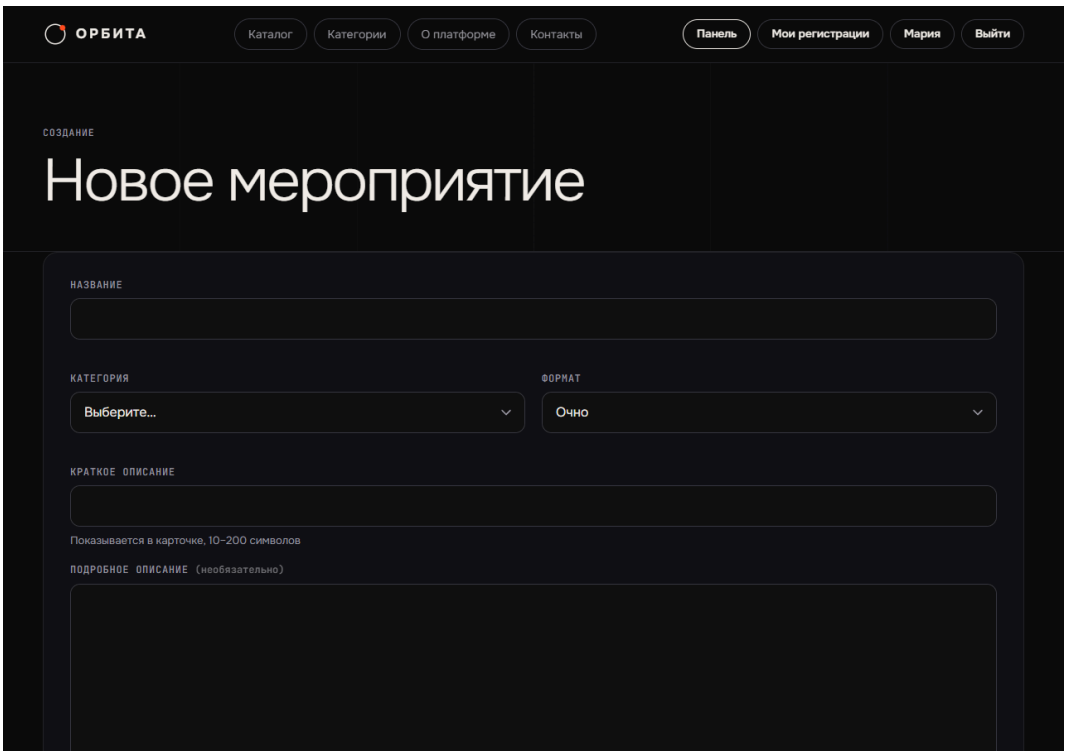


Рисунок №14 – Форма создания мероприятия

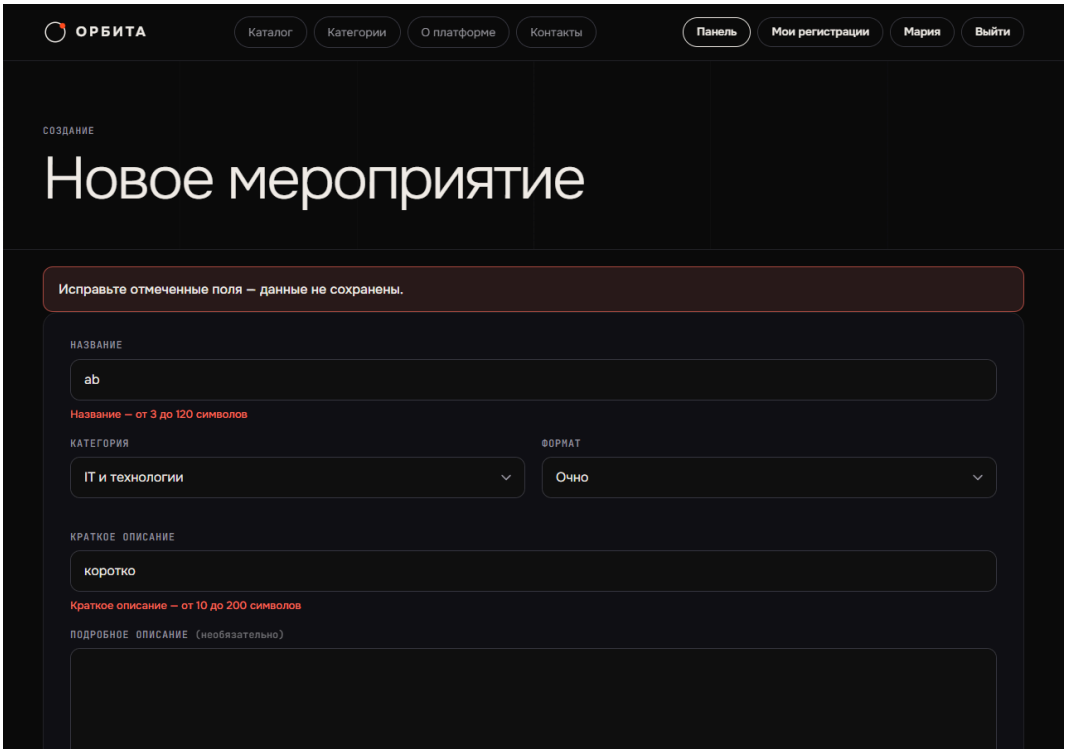


Рисунок №15 – Ошибки валидации формы: введённые значения сохранены

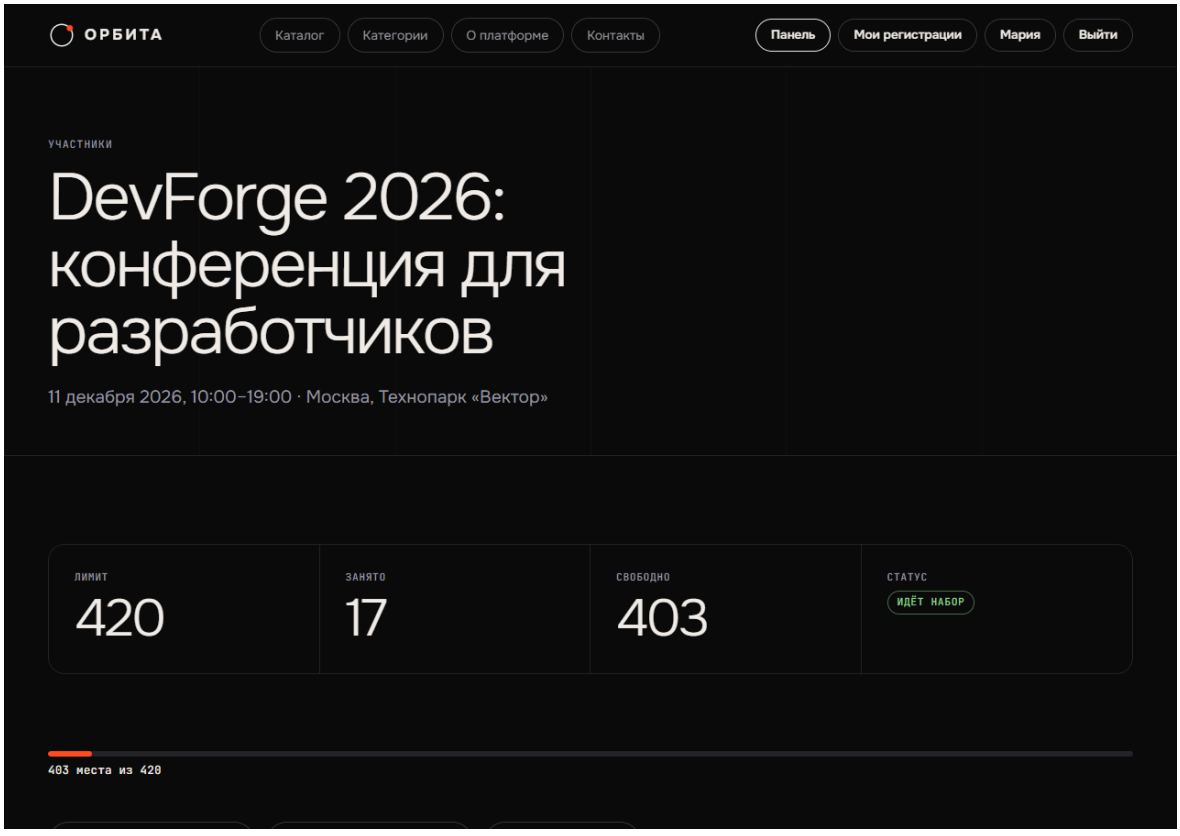


Рисунок №16 – Список участников, свободные места и действия организатора

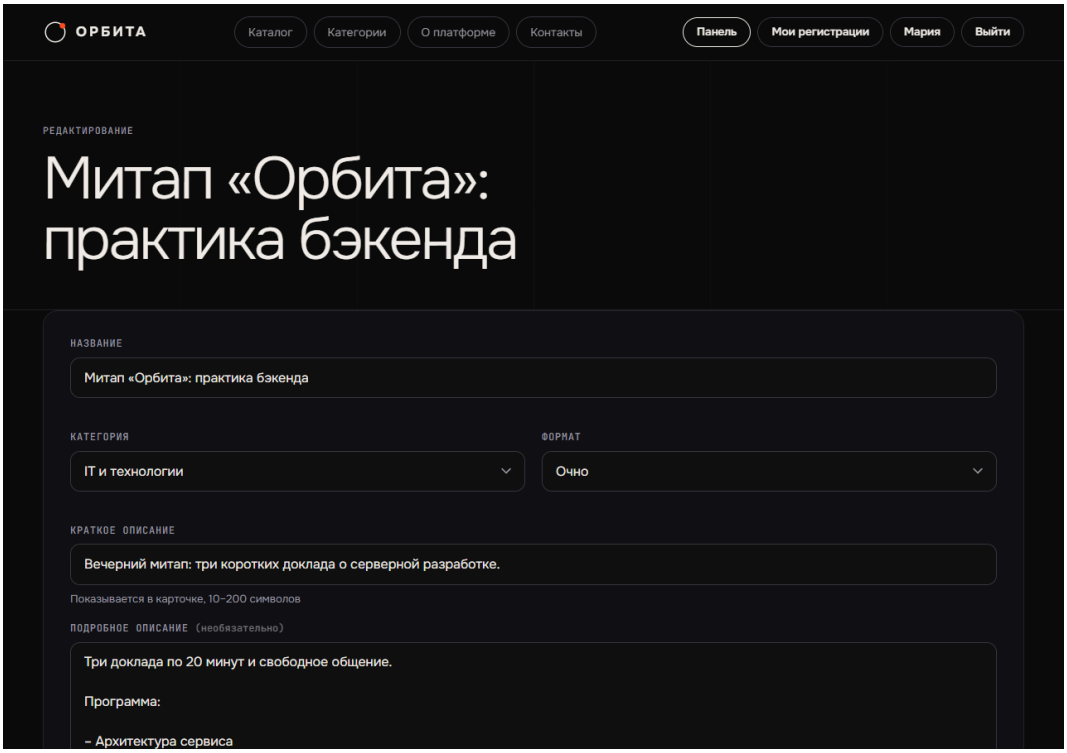


Рисунок №17 – Редактирование мероприятия

5. Проверить адаптивность:

Страницы проверены при ширине 360, 768 и 1280 px: горизонтального переполнения нет (скрипт снимков проверяет scrollWidth для каждого из 47 снимков), таблицы панели на узком экране превращаются в карточки, все поля имеют подписи, у элементов виден фокус (рисунки №18–№20).

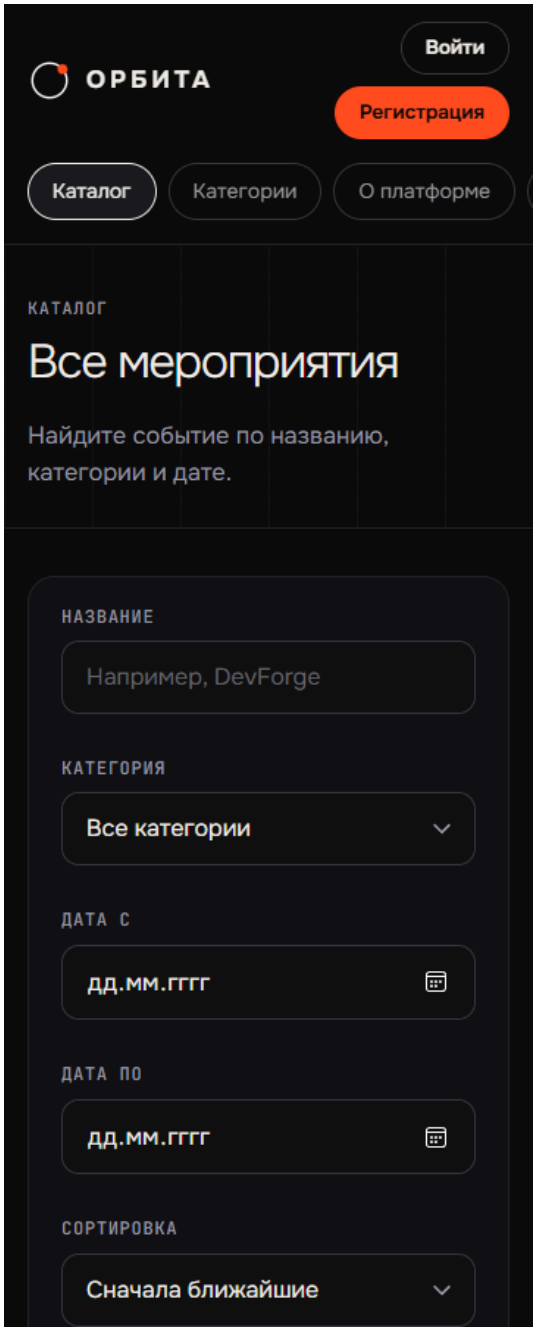


Рисунок №18 – Каталог при ширине 360 px

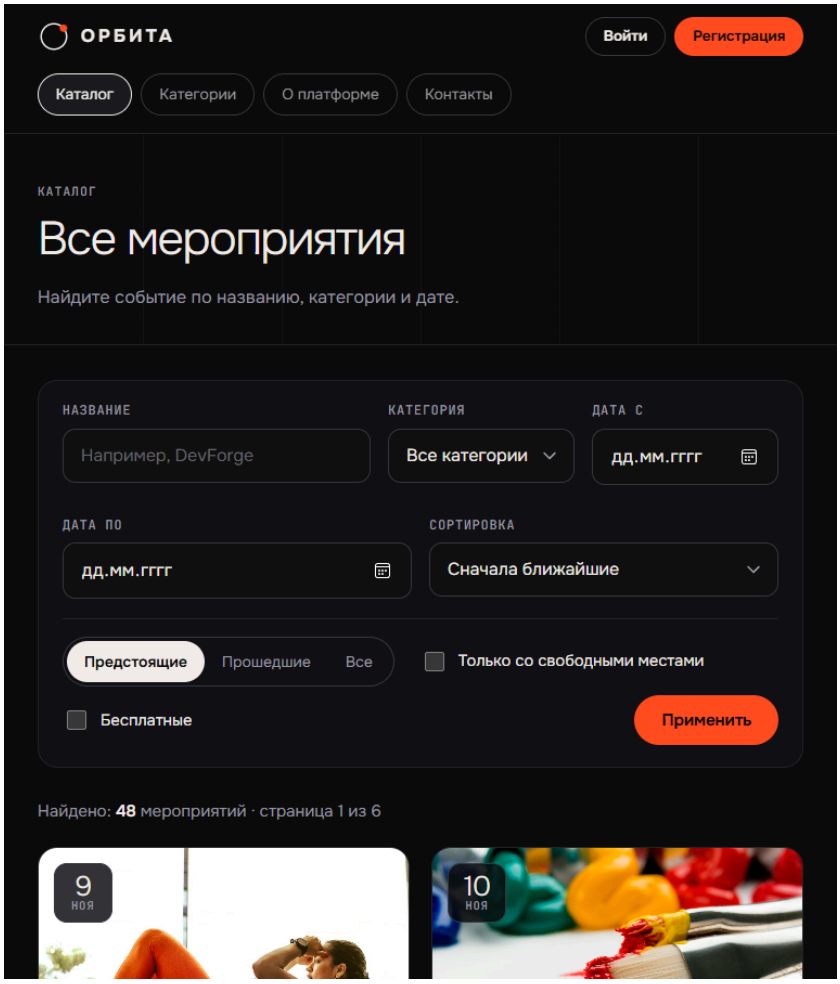


Рисунок №19 – Каталог при ширине 768 px

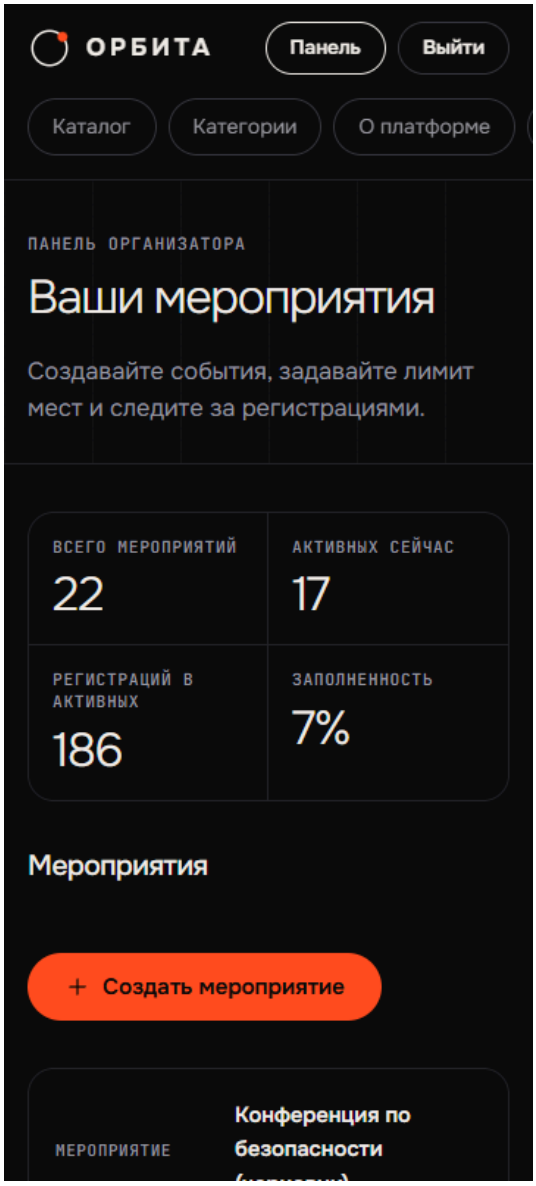


Рисунок №20 – Панель организатора при ширине 360 px: таблица в виде карточек

Вывод: реализованы все страницы из задания (главная, каталог, мероприятие, категории, кабинет, мои регистрации, панель, создание и редактирование, вход и регистрация, о платформе, контакты, администрирование); интерфейс адаптивен, данные читаются из БД, ошибки 401/403/404 обработаны без вывода внутренних сведений.

Тема 5: Правило темы — регистрация на мероприятие и лимит участников.

Цель: реализовать регистрацию и отмену так, чтобы число активных регистраций не превышало лимит, а повторная регистрация была невозможна, и проверить поведение при одновременных запросах.

Предметная область: мероприятия с ограниченным числом мест.

Ход работы:

1. Реализовать защиту правила на трёх уровнях:

Первый уровень — функция registerForEvent выполняет вставку в транзакции BEGIN IMMEDIATE: запись блокируется для других соединений, проверка и вставка не разделяются чужим запросом. Второй уровень — триггер trg_reg_insert отклоняет вставку, если активных регистраций уже не меньше лимита (EVENT_FULL), и вставку на неопубликованное событие (EVENT_CLOSED). Третий уровень — частичный уникальный индекс не допускает две активные регистрации одного пользователя на событие. Триггер trg_event_capacity запрещает уменьшить лимит ниже числа занятых мест (листинг №6).

Листинг №6 – регистрация на мероприятие (src/rules.js)

```
export function registerForEvent(db, user, eventId) {
  const ev = getEvent(db, eventId);
  if (!ev) throw new HttpError(404, 'Мероприятие не найдено');
  const state = eventState(ev);
  if (state === 'cancelled') throw new HttpError(409, 'Мероприятие отменено
организатором');
  if (state === 'draft') throw new HttpError(404, 'Мероприятие не найдено');
  if (state === 'past' || state === 'started') throw new HttpError(409,
'Регистрация закрыта: мероприятие уже началось');
  try {
    return db.tx(() => {
      const r = db.run("INSERT INTO registrations(event_id, user_id, status)
VALUES (?,?, 'active')", ev.id, user.id);
      const taken = db.get("SELECT count(*) AS n FROM registrations WHERE
event_id = ? AND status = 'active'", ev.id).n;
      return { id: Number(r.lastInsertRowid), event: ev, left: ev.capacity -
taken };
    });
  } catch (e) {
    const msg = String(e.message);
    if (msg.includes('EVENT_FULL')) throw new HttpError(409, 'Свободных мест
не осталось: лимит участников достигнут');
    if (msg.includes('EVENT_CLOSED')) throw new HttpError(409, 'Регистрация
на это мероприятие недоступна');
    if (msg.includes('UNIQUE constraint failed')) throw new HttpError(409,
'Вы уже зарегистрированы на это мероприятие');
    throw e;
  }
}
```

2. Обработать результат и сообщить пользователю:

Ошибки базы преобразуются в понятные сообщения: «Свободных мест не осталось: лимит участников достигнут», «Вы уже зарегистрированы на это мероприятие», «Регистрация закрыта: мероприятие уже началось». При успехе показывается число оставшихся мест. После достижения лимита кнопка на странице неактивна (рисунки №21–№26).

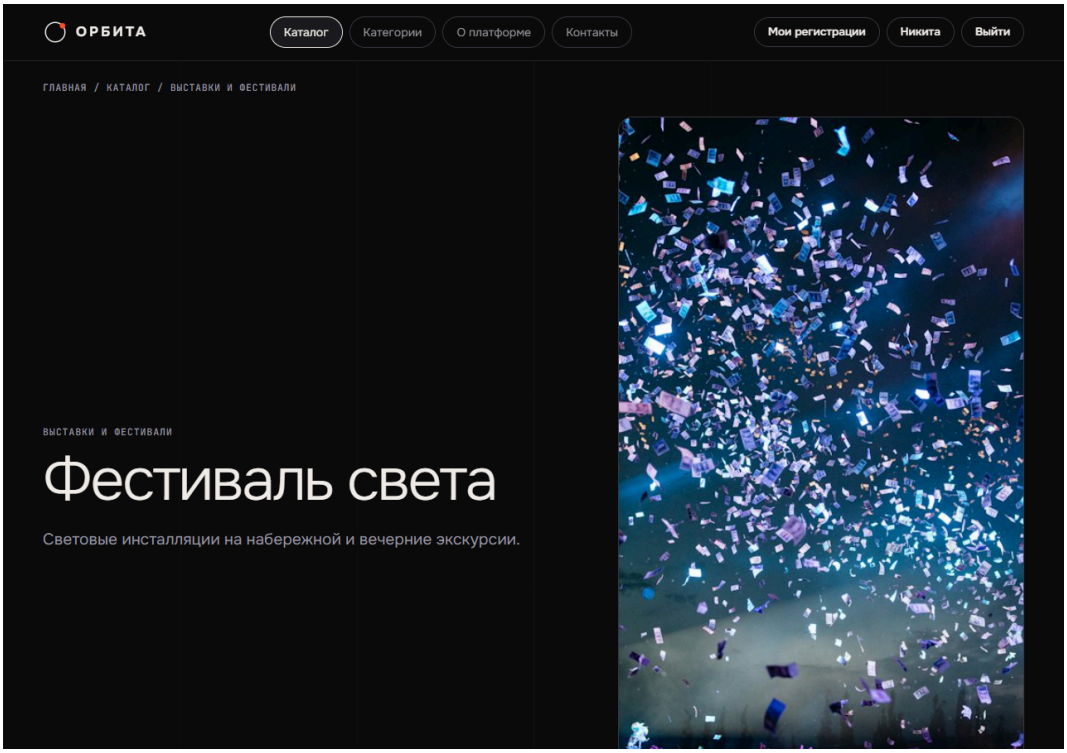


Рисунок №21 – Мероприятие со свободными местами: кнопка «Зарегистрироваться»

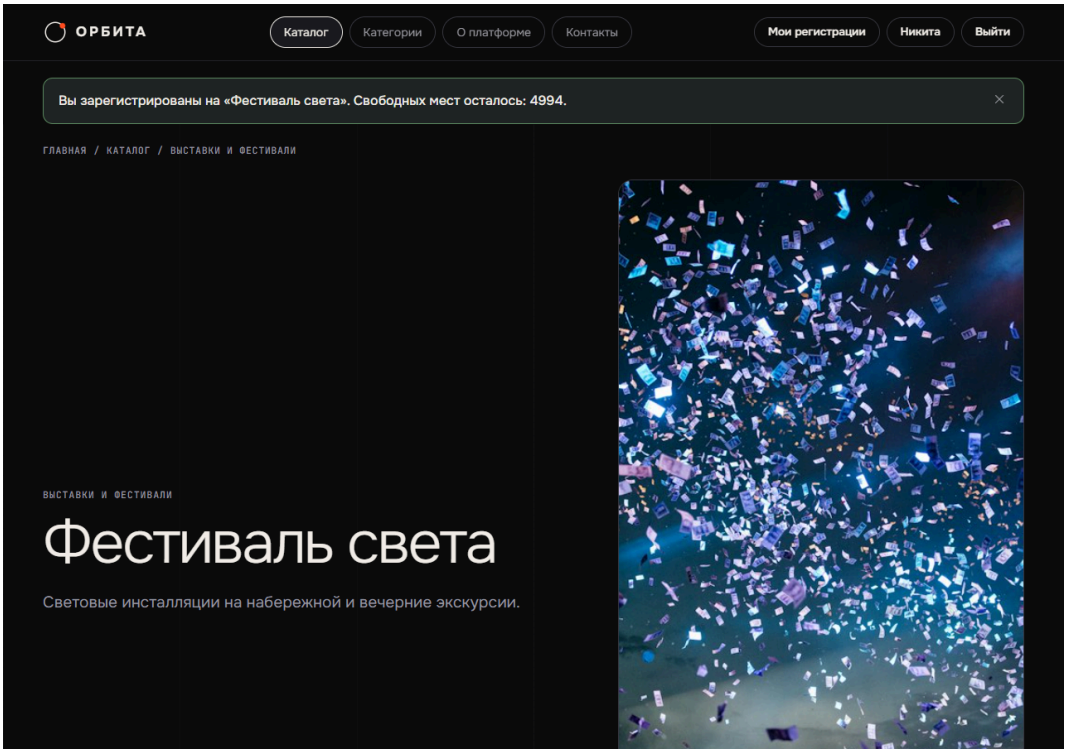


Рисунок №22 – Успешная регистрация: уведомление и кнопка отмены

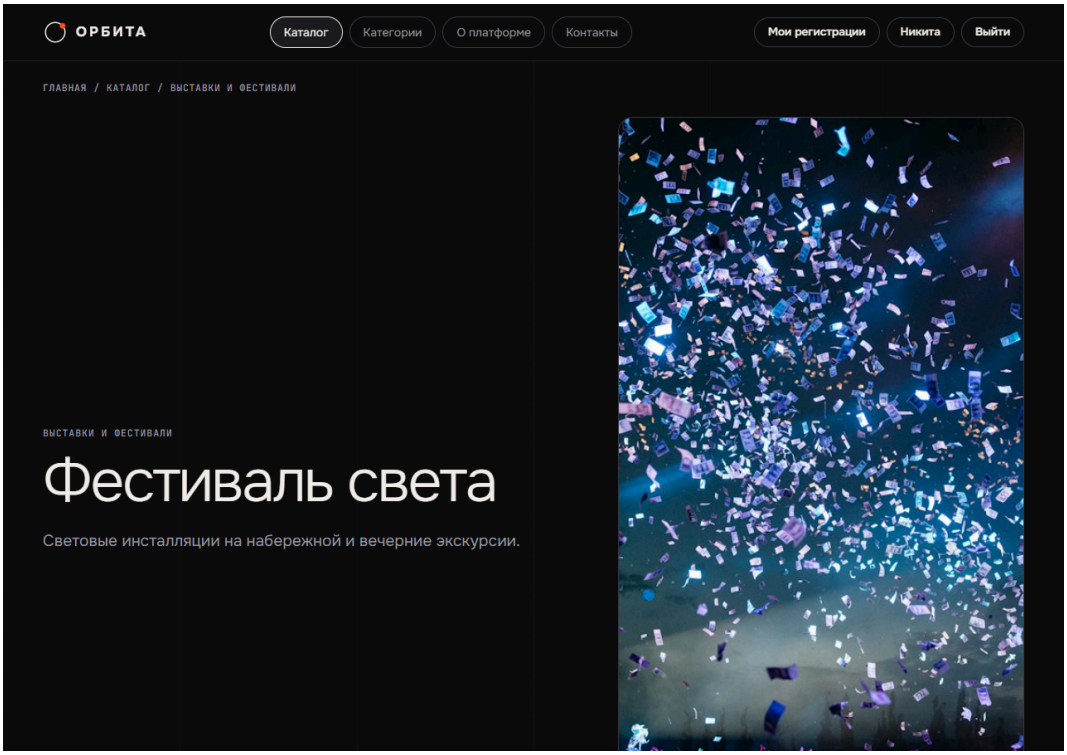


Рисунок №23 – Повторная регистрация: уведомление об отказе

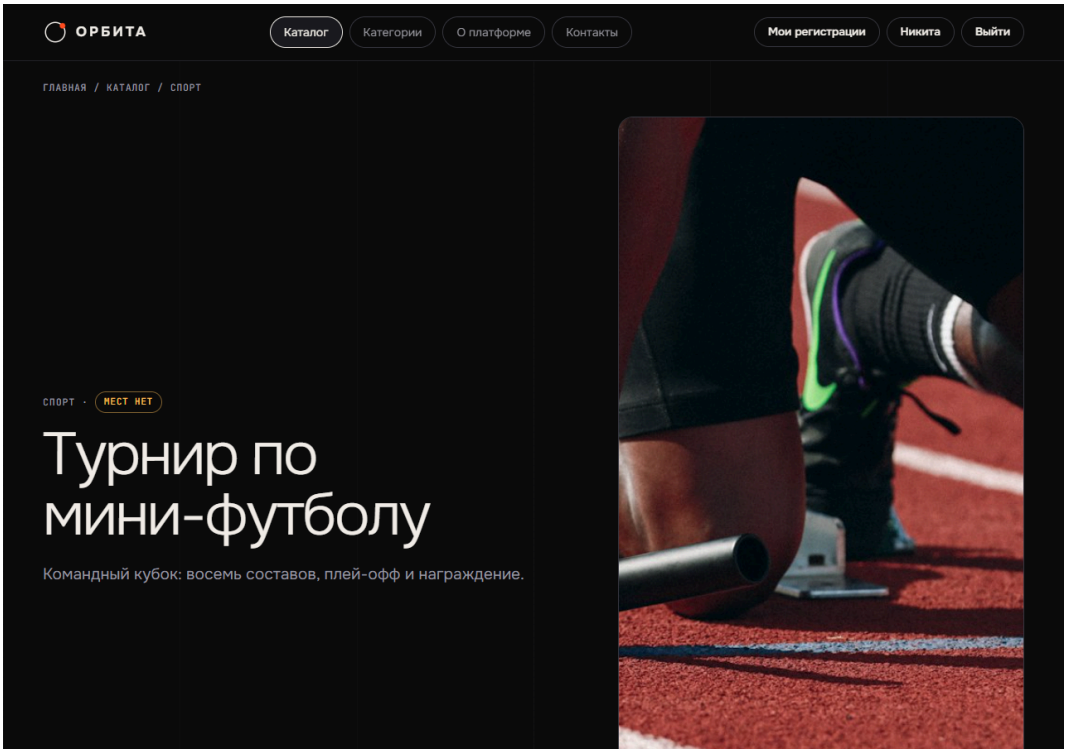


Рисунок №24 – Лимит достигнут: кнопка «Мест нет» неактивна

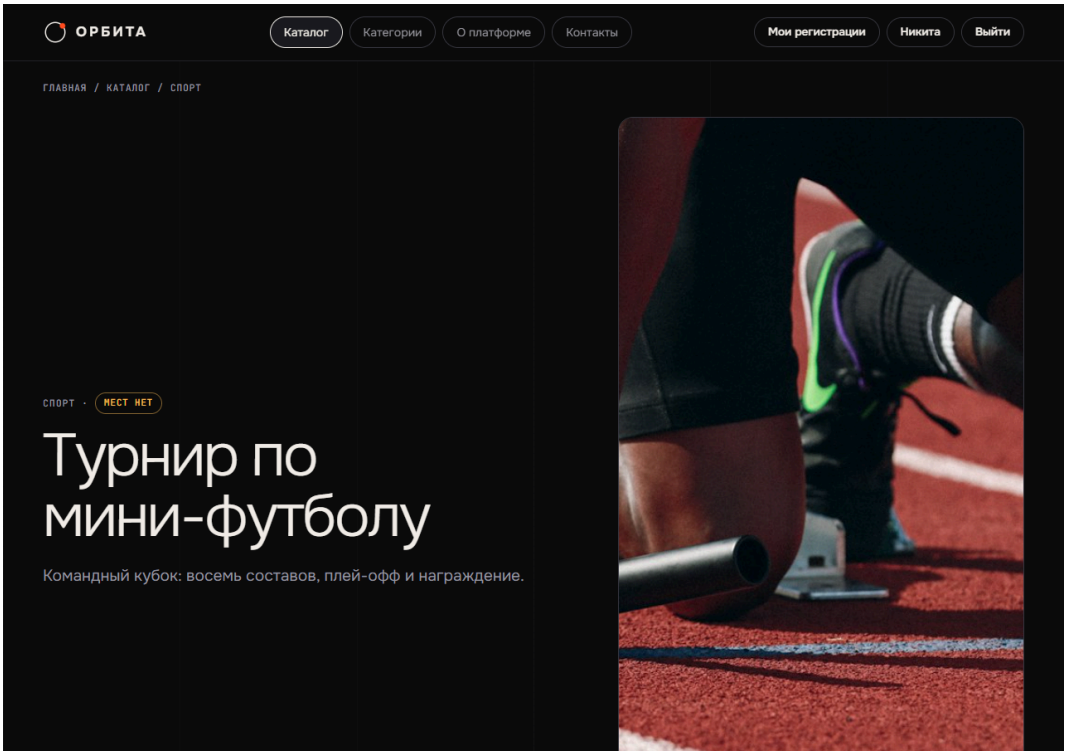


Рисунок №25 – Попытка записи на заполненное мероприятие в обход кнопки: отказ сервера

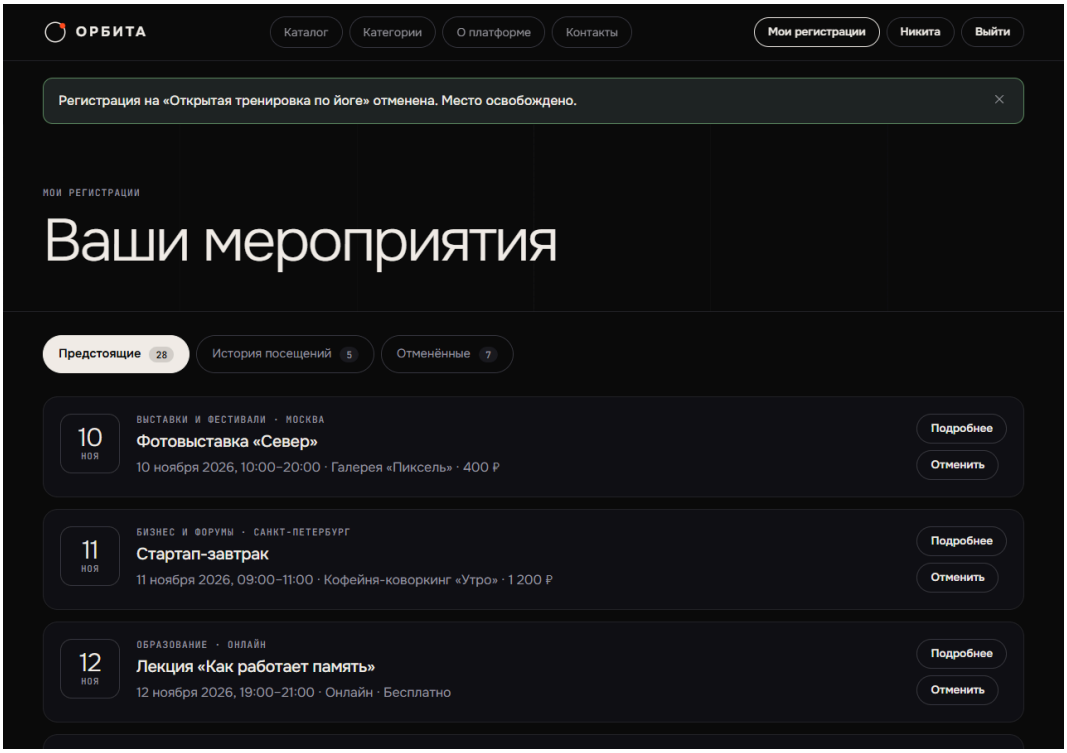


Рисунок №26 – Отмена регистрации: место освобождено

3. Проверить граничные случаи:

Таблица №12 – Проверка регистрации и отмены

Проверка	Результат
Анонимная регистрация — 401	Выполнено
Успешная регистрация: уведомление и 1 активная запись	Выполнено
Повторная регистрация того же пользователя отклонена	Выполнено
При достижении лимита регистрация недоступна	Выполнено
Отмена освобождает место, его занимает другой участник	Выполнено
Чужую регистрацию отменить нельзя — 403	Выполнено
Отмена после начала мероприятия невозможна — 409	Выполнено
Регистрация на уже начавшееся мероприятие закрыта	Выполнено
Регистрация на отменённое мероприятие отклонена	Выполнено
Черновик скрыт: регистрация и просмотр — 404	Выполнено
30 одновременных запросов на 5 мест — занято ровно 5	Выполнено
Запрос без CSRF-токена отклонён — 403	Выполнено

Тест B11: 30 авторизованных клиентов одновременно отправили запрос на мероприятие с лимитом 5 — в БД ровно 5 активных регистраций, остальные получили сообщение об отсутствии мест. Тест A11: четыре отдельных процесса по 20 вставок напрямую в файл БД (без приложения) на лимит 10 — занято ровно 10, остальные вставки отклонены триггером.

Вывод: правило темы работает на уровне приложения и базы; 12 из 12 проверок регистрации и отмены выполнены.

Тема 6: Тестирование и проверка безопасности.

Цель: составить и выполнить не менее 15 тестов, зафиксировать дефекты и повторные проверки, проверить безопасность собственного приложения.

Предметная область: функциональное и защитное тестирование веб-приложения.

Ход работы:

1. Указать среду и дату проверки:

Проверка выполнена 07.11.2026 командой npm test на компьютере разработчика: Windows 10 Pro (19045), Intel Core i5-9400F, Node.js v24.19.0, SQLite 3.53. Тесты запускают сервер на временной БД с учебными данными и обращаются к нему по HTTP через fetch (с cookie и CSRF-токенами), а также напрямую проверяют ограничения БД. Рабочая БД не затрагивается.

2. Результаты тестов:

Таблица №13 – Протокол функционального тестирования (60 проверок)

№	Код ФТ	Данные, действие и ожидаемый результат	Фактически	Статус
1	ФТ-03	A1 Дубль активной регистрации отклонён индексом UNIQUE	Результат совпал с ожидаемым	успешно
2	ФТ-03	A2 Превышение лимита отклонено триггером EVENT_FULL	Результат совпал с ожидаемым	успешно
3	ФТ-03	A3 Запись на черновик отклонена (EVENT_CLOSED)	Результат совпал с ожидаемым	успешно
4	ФТ-03	A4 Лимит нельзя уменьшить ниже числа активных регистраций	Результат совпал с ожидаемым	успешно
5	ФТ-03	A5 Неверная ссылка (несуществующий пользователь) — FOREIGN KEY	Результат совпал с ожидаемым	успешно
6	ФТ-03	A6 Отрицательная цена отклонена ограничением CHECK	Результат совпал с ожидаемым	успешно
7	ФТ-03	A7 Мероприятие нельзя создать от имени обычного пользователя	Результат совпал с ожидаемым	успешно
8	ФТ-03	A8 Дубль логина без учёта регистра отклонён	Результат совпал с ожидаемым	успешно
9	ФТ-03	A9 Каскад: при удалении мероприятия удаляются его регистрации	Результат совпал с ожидаемым	успешно
10	ФТ-03	A10 После отмены повторная запись допустима, занято мест — 1	Результат совпал с ожидаемым	успешно
11	ФТ-03	A11 Одновременные процессы (4×20 вставок на 10 мест): занято ровно 10	Результат совпал с ожидаемым	успешно
12	ФТ-03	B1 Анонимная регистрация — 401	Результат совпал с ожидаемым	успешно

№	Код ФТ	Данные, действие и ожидаемый результат	Фактически	Статус
13	ФТ-03	B2 Успешная регистрация: уведомление и 1 активная запись	Результат совпал с ожидаемым	успешно
14	ФТ-03	B3 Повторная регистрация того же пользователя отклонена	Результат совпал с ожидаемым	успешно
15	ФТ-03	B4 При достижении лимита регистрация недоступна	Результат совпал с ожидаемым	успешно
16	ФТ-03	B5 Отмена освобождает место, его занимает другой участник	Результат совпал с ожидаемым	успешно
17	ФТ-03	B6 Чужую регистрацию отменить нельзя — 403	Результат совпал с ожидаемым	успешно
18	ФТ-03	B7 Отмена после начала мероприятия невозможна — 409	Результат совпал с ожидаемым	успешно
19	ФТ-03	B8 Регистрация на уже начавшееся мероприятие закрыта	Результат совпал с ожидаемым	успешно
20	ФТ-03	B9 Регистрация на отменённое мероприятие отклонена	Результат совпал с ожидаемым	успешно
21	ФТ-03	B10 Черновик скрыт: регистрация и просмотр — 404	Результат совпал с ожидаемым	успешно
22	ФТ-03	B11 30 одновременных запросов на 5 мест — занято ровно 5	Результат совпал с ожидаемым	успешно
23	ФТ-03	B12 Запрос без CSRF-токена отклонён — 403	Результат совпал с ожидаемым	успешно
24	ФТ-01	C1 Поиск по названию без учёта регистра (кириллица)	Результат совпал с ожидаемым	успешно
25	ФТ-01	C2 Фильтр по категории возвращает только её мероприятия	Результат совпал с ожидаемым	успешно
26	ФТ-01	C3 Фильтр по датам «с — по»	Результат совпал с ожидаемым	успешно
27	ФТ-01	C4 Сортировка: по популярности и по цене	Результат совпал с ожидаемым	успешно
28	ФТ-01	C5 Фильтр «только со свободными местами» исключает заполненные	Результат совпал с ожидаемым	успешно
29	ФТ-01	C6 Постраничный вывод сохраняет условия фильтра в ссылках	Результат совпал с ожидаемым	успешно
30	ФТ-01	C7 Номер страницы за пределами диапазона приводится к последней	Результат совпал с ожидаемым	успешно
31	ФТ-01	C8 Пустой результат: понятное сообщение, статус 200	Результат совпал с ожидаемым	успешно
32	ФТ-01	C9 Черновики не попадают в каталог и карту сайта	Результат совпал с ожидаемым	успешно
33	ФТ-07	C10 Пользовательский текст экранируется (XSS в названии)	Результат совпал с ожидаемым	успешно
34	ФТ-07	C11 SQL-инъекция в поиске не раскрывает данные (запрос параметризован)	Результат совпал с ожидаемым	успешно
35	ФТ-02	C12 Несуществующее и некорректное мероприятие — 404	Результат совпал с ожидаемым	успешно
36	ФТ-07	D1 Анонимный доступ к панели организатора — 401, к кабинету — 401	Результат совпал с ожидаемым	успешно

№	Код ФТ	Данные, действие и ожидаемый результат	Фактически	Статус
37	ФТ-07	D2 Обычный пользователь не попадает в панель организатора — 403	Результат совпал с ожидаемым	успешно
38	ФТ-07	D3 Организатор не может изменить и удалить чужое мероприятие — 403	Результат совпал с ожидаемым	успешно
39	ФТ-04	D4 Список участников чужого мероприятия и CSV недоступны — 403	Результат совпал с ожидаемым	успешно
40	ФТ-07	D5 Раздел администратора: админ — 200, организатор — 403	Результат совпал с ожидаемым	успешно
41	ФТ-04	D6 После выхода старый сеанс не даёт доступа — 401	Результат совпал с ожидаемым	успешно
42	ФТ-04	D7 Неверный пароль — 401 без выдачи сеанса пользователя	Результат совпал с ожидаемым	успешно
43	ФТ-04	D8 Шесть неверных входов подряд — блокировка 429, верный пароль тоже отклоняется	Результат совпал с ожидаемым	успешно
44	ФТ-04	D9 Идентификатор сеанса меняется при входе, cookie HttpOnly + SameSite	Результат совпал с ожидаемым	успешно
45	ФТ-04	D10 Перенаправление после входа только на внутренние адреса	Результат совпал с ожидаемым	успешно
46	ФТ-07	D11 Пароли хранятся только в виде хеша scrypt	Результат совпал с ожидаемым	успешно
47	ФТ-07	D12 Заголовки безопасности (CSP, nosniff, запрет фреймов)	Результат совпал с ожидаемым	успешно
48	ФТ-04	D13 Регистрация аккаунта: слабый пароль и занятый логин — 422	Результат совпал с ожидаемым	успешно
49	ФТ-04	D14 Успешная регистрация участника и организатора, вход выполнен сразу	Результат совпал с ожидаемым	успешно
50	ФТ-06	E1 Некорректная форма: ошибки по полям, мероприятие не создано (422)	Результат совпал с ожидаемым	успешно
51	ФТ-06	E2 Корректная форма создаёт мероприятие организатора и показывает его в каталоге	Результат совпал с ожидаемым	успешно
52	ФТ-06	E3 Редактирование сохраняет изменения; лимит ниже занятых мест — 422	Результат совпал с ожидаемым	успешно
53	ФТ-06	E4 Список участников: видны зарегистрированные, счётчик мест верный	Результат совпал с ожидаемым	успешно
54	ФТ-06	E5 Организатор отменяет регистрацию участника — место освобождается	Результат совпал с ожидаемым	успешно
55	ФТ-06	E6 Отметка присутствия: организатор — 303, участник — 403	Результат совпал с ожидаемым	успешно
56	ФТ-06	E7 Удаление мероприятия с регистрациями запрещено, без регистраций — выполняется	Результат совпал с ожидаемым	успешно
57	ФТ-06	E8 Выгрузка CSV: только активные участники, BOM и защита от формул	Результат совпал с ожидаемым	успешно
58	ФТ-05	E9 Личный кабинет: вкладки предстоящих, истории и отменённых	Результат совпал с ожидаемым	успешно
59	ФТ-08	E10 Статистика обращений: журнал ведётся, ошибки учитываются	Результат совпал с ожидаемым	успешно

№	Код ФТ	Данные, действие и ожидаемый результат	Фактически	Статус
60	ФТ-08	E11 SEO: sitemap.xml, robots.txt закрывает кабинет, у страниц есть title/description/canonical	Результат совпал с ожидаемым	успешно

Успешно: 60, неуспешно: 0, не выполнено: 0, заблокировано: 0. Ожидаемый результат каждой проверки задан в её условии и закреплён в программном утверждении (assert), поэтому «Фактически» отражает совпадение с ожидаемым. Вывод запуска показан на рисунке №27.

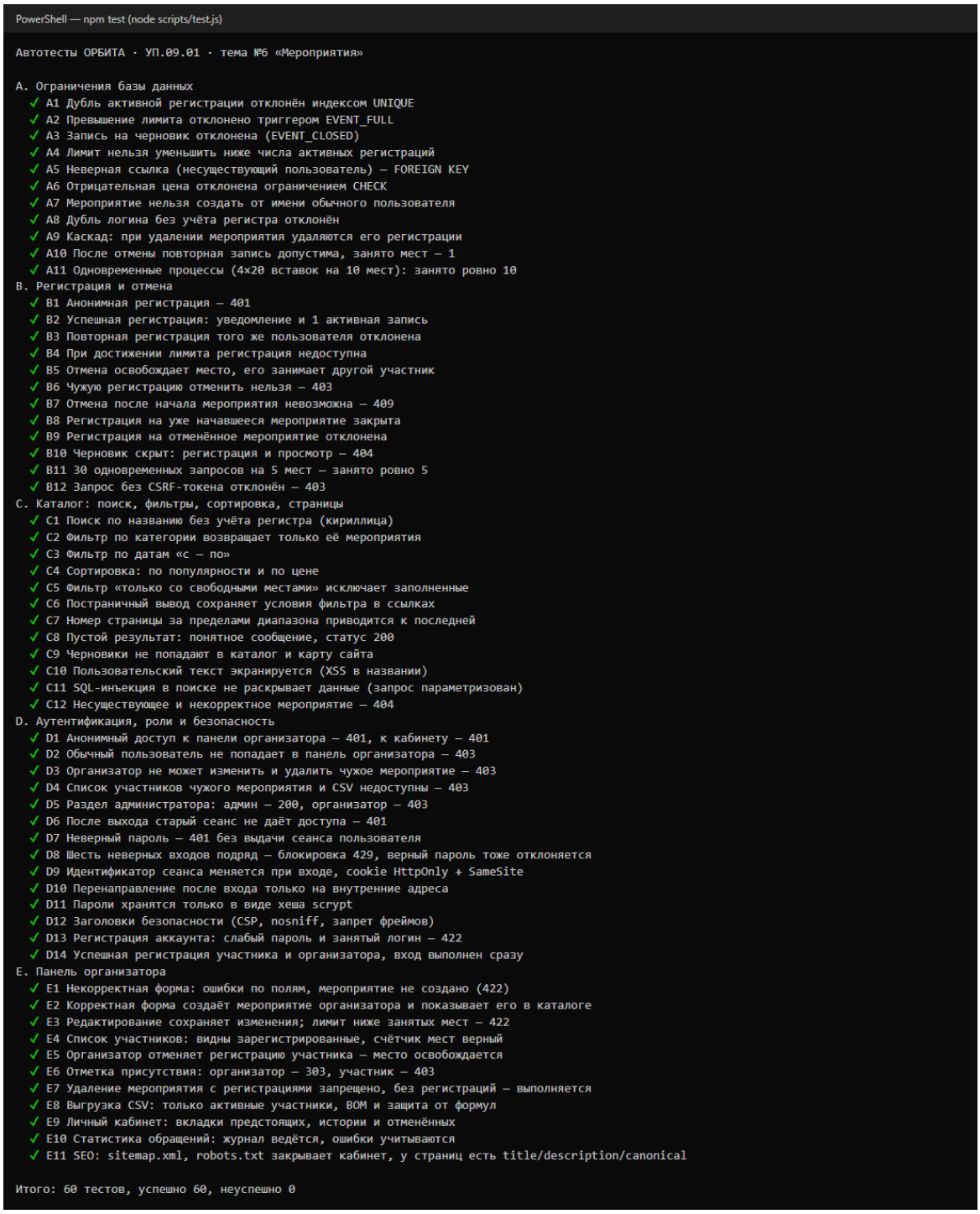


Рисунок №27 – Результат запуска npm test: 60 тестов, 60 успешно

3. Обнаруженные дефекты и повторные проверки:

Таблица №14 – Журнал дефектов

№	Описание	Причина	Исправление и повторная проверка
Д-01	Автотест С6 не прошёл при первом запуске (59 из 60)	Тест требовал строго заданный порядок параметров в ссылке; приложение сохраняет оба параметра	Проверка переписана на независимую от порядка; повторный прогон — 60 из 60
Д-02	Снимок главной: карточки ниже экрана без обложек	Ленивая загрузка изображений при съёмке всей страницы	Сценарий съёмки прокручивает страницу; снимок пересобран
Д-03	У «Открытой тренировки по йоге» отображалось фото бассейна	Фото выбиралось только по номеру события	Добавлен подбор фото по ключевым словам названия; проверено на главной и в карточке

4. Проверить безопасность:

Проверки выполнены в собственном приложении. Механизм входа — серверный сеанс в cookie, поэтому CSRF-защита применима и реализована.

Таблица №15 – Чек-лист безопасности

Пункт	Результат и доказательство
Параметризация SQL	Выполнено: значения передаются через «?», порядок сортировки — из белого списка; ввод «' OR 1=1 --» даёт 0 результатов (С11)
Экранирование вывода	Выполнено: <script> в названии выводится текстом (С10)
CSRF	Выполнено: POST без токена — 403 (В12)
Пароли и сеансы	Выполнено: scrypt, SHA-256 идентификатора, HttpOnly + SameSite=Lax, смена при входе (D6, D9, D11)
Права на сервере	Выполнено: 401/403 для прямых запросов (В6, D1–D5)
Перебор паролей	Выполнено: блокировка после 5 неудач (D8)
Открытое перенаправление	Выполнено: next только внутренний путь (D10)
Заголовки безопасности	Выполнено: CSP, nosniff, X-Frame-Options (D12)
Секреты в репозитории	Выполнено: .env не хранится; в репозитории только учебный пароль демонстрационных записей
Ошибки без внутренних сведений	Выполнено частично: общая страница 500 при DEBUG_ERRORS=0; автотеста нет, проверено чтением кода
Загрузка файлов	Неприменимо: не реализована

Вывод: выполнено 60 тестов, из них 60 успешно; найдено три дефекта (один — в тесте, два — в процессе проверки), все исправлены и перепроверены; чек-лист безопасности закрыт, кроме HTTPS (не настраивался).

Тема 7: Статистика, оптимизация, SEO, размещение и восстановление.

Цель: измерить производительность до и после оптимизации, собрать статистику обращений, доработать SEO, подготовить анонс, создать резервную копию и проверить восстановление.

Предметная область: эксплуатация и продвижение веб-приложения.

Ход работы:

1. Описать сценарий и условия измерения:

Сценарий: GET /events?when=all&sort=popular&page=3. Среда: Windows 10 Pro 19045, Intel Core i5-9400F 2.90 ГГц, Node.js v24.19.0; клиент и сервер на одной машине. Данные одинаковы для «до» и «после»: 2963 мероприятия, 31 433 регистраций. Замер — среднее по 10 запросам после прогрева; замеров три; единицы — миллисекунды.

2. Статистика обращений и расчёт показателей:

Учебный сценарий (scripts/traffic.js) выполнил 43 обращения к приложению: просмотр, поиск, регистрация, ошибки доступа. Журнал без персональных данных сохранён в файле журнал_обращений.csv (время, маршрут, статус, длительность).

Таблица №16 – Статистика обращений

Показатель	Результат
Число запросов	43
Число ошибочных ответов (4xx)	8 (401 — 4, 403 — 2, 404 — 2)
Доля ошибочных ответов	8 / 43 = 18,6 %
Медиана длительности	1,07 мс

Доля ошибок высока, так как сценарий намеренно содержит обращения к закрытым и несуществующим адресам; журнал собран одним пользователем на локальном сервере, поэтому описывает скорость обработки, а не поведение аудитории.

3. Изменения и результаты повторных измерений:

Таблица №17 – Результаты замеров до и после оптимизации

Мера и версия	Замер 1	Замер 2	Замер 3	Медиана	Запросов к БД	Размер ответа
Индексы: До: без индексов	15,19	15,67	15,66	15,66	4	3367 Б
Индексы: После: с индексами	14,58	14,11	15,6	14,58	4	3367 Б

Мера и версия	Замер 1	Замер 2	Замер 3	Медиана	Запросов к БД	Размер ответа
Сжатие: До: без Accept-Encoding	16	15,83	14,29	15,83	4	15971 Б
Сжатие: После: gzip	15,35	15,86	15,83	15,83	4	3367 Б
N+1: До: 1 + 9 запросов к БД	0,1	0,1	0,1	0,1	10	—
N+1: После: 1 запрос к БД	0,05	0,05	0,05	0,05	1	—

Индексы (миграция 002_indexes.sql) ускорили страницу на 6,9 % (15,66 → 14,58 мс): выигрыш сопоставим с разбросом замеров, так как основное время уходит на сортировку по числу занятых мест и сборку страницы. Сжатие gzip уменьшило ответ с 15971 до 3367 Б (−78,9 %), время на localhost не изменилось. Устранение N+1 сократило число запросов к БД с 10 до 1 при выборке девяти карточек. Дальнейшая мера (счётчик занятых мест в таблице событий) не выполнялась.

4. SEO и результаты учебного продвижения:

Таблица №18 – SEO-проверки публичных страниц

Пункт	Изменение и результат проверки
title и description	Уникальны у каждой страницы: главная — 62/148 знаков, каталог — 57/138, карточка — 57/140
Структура заголовков	На каждой странице один h1 (проверено для 6 страниц), далее h2 и h3
Ссылки и alt	Все изображения с alt (главная 7 из 7, каталог 9 из 9, карточка 4 из 4)
Карта сайта и индексация	sitemap.xml: 72 адресов, без черновиков; robots.txt указывает Sitemap; canonical, Open Graph и schema.org Event на карточке
Закрытые разделы	Кабинет, панель, вход и поиск — noindex; /account, /organizer, /admin закрыты в robots.txt

Целевая аудитория анонса: студенты и жители города, начинающие организаторы. Макет анонса подготовлен (файл SEO_и_продвижение.md). Публикация в учебном интернет-канале НЕ выполнялась — действие отмечено как невыполненное; переход проверен только локально и по адресу в локальной сети http://192.168.0.11:3000 (код 200) с того же компьютера, с другого рабочего места проверка не проводилась.

5. Создать резервную копию и проверить восстановление:

Команда npm run backup создала копию БД (SQLite VACUUM INTO) и манифест с числом записей; команда npm run restore скопировала её в отдельную БД и выполнила проверки (рисунок № 28, таблица № 19). Подробный протокол — файл Протокол_восстановления.md.

Таблица №19 – Результаты проверки восстановления

Проверка	Фактический результат
Запуск приложения	БД открыта модулем приложения; каталог читается (60 опубликованных событий)
Количество записей и связи	users 26, categories 6, events 63, registrations 727, messages 0 — как в манифесте; integrity_check = ok; нарушений внешних ключей нет
Чтение и изменение данных	Запись пользователя на мероприятие: занято 9 → 10, отмена → 9
Права и правила	Повторная запись отклонена; превышений лимита нет
Основной сценарий	Запись и отмена выполнены над восстановленной БД

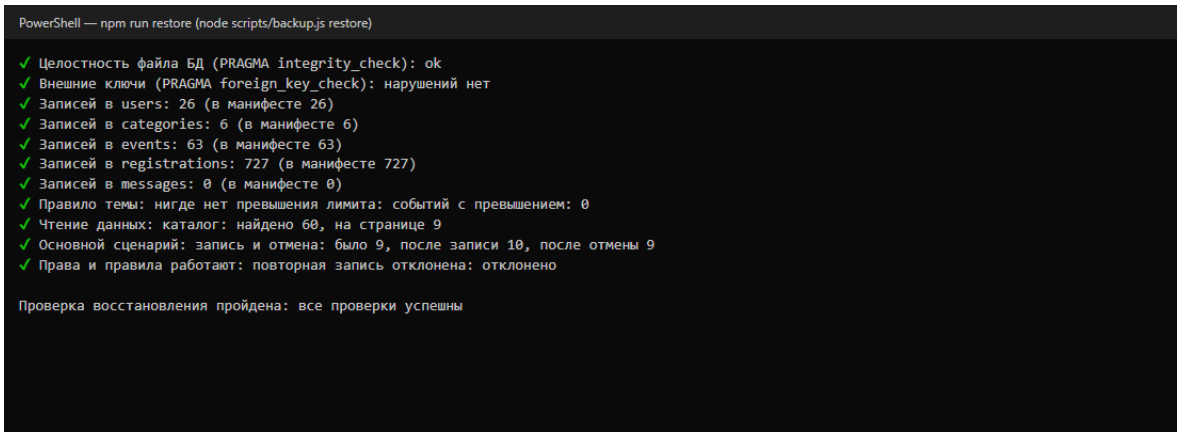


Рисунок №28 – Проверка восстановления резервной копии (npm run restore)

6. Подготовить состав комплекта сдачи:

Таблица №20 – Состав комплекта сдачи

Папка	Состав
01_Проект	Исходный код, README, миграции, скрипты, .env.example
02_Данные	Схема БД, миграции, ER-диаграмма, резервная копия, вывод команд
03_Проектирование	ТЗ, карта страниц, прототипы
04_Проверки	Протокол тестирования, журнал дефектов, чек-лист безопасности, снимки экранов, результаты автотестов
05_Измерения	Протокол измерений, журнал обращений (43 запроса), замеры
06_SEO_Продвижение	SEO-проверка и макет анонса
07_Документы	Отчёт, дневник, протокол восстановления, матрица соответствия, личный план

Вывод: выполнены замеры и статистика, применены три меры оптимизации (измеримый эффект — по размеру ответа и числу запросов), проверено SEO, создана копия и проверено восстановление. Не выполнены: публикация анонса, проверка с другого рабочего места и запуск проекта другим студентом.

Заключение.

В ходе практики разработана платформа «ОРБИТА»: каталог мероприятий, регистрация с гарантированным лимитом участников, личный кабинет, панель организатора, роли и защита данных. Получены и проверены результаты, приведённые в таблице №21.

Таблица №21 – Выполнение требований по теме «Мероприятия»

Код	Требование	Статус	Доказательство
ФТ-01	Каталог, поиск, фильтры, сортировка, страницы	Выполнено	Тесты C1–C8, рисунки каталога
ФТ-02	Страница мероприятия	Выполнено	Тест C12, рисунок страницы мероприятия
ФТ-03	Регистрация, лимит, дубль, отмена	Выполнено	Тесты A1–A11, B1–B12
ФТ-04	Аккаунты и роли	Выполнено	Тесты D6–D14
ФТ-05	Личный кабинет	Выполнено	Тест E9, рисунки кабинета
ФТ-06	Панель организатора	Выполнено	Тесты E1–E8, рисунки панели
ФТ-07	Защита данных	Выполнено	Чек-лист безопасности
ФТ-08	SEO и статистика	Выполнено	Тест E10–E11, seo_проверка.json
—	Публикация анонса, проверка с другого рабочего места, запуск другим студентом	Не выполнено	Требуется стенд и согласование с руководителем

Ограничения и план доработки: хранить счётчик занятых мест в таблице событий для ускорения сортировки; добавить лист ожидания и письма-подтверждения; настроить HTTPS при размещении; выполнить публикацию анонса и проверку запуска другим пользователем; провести проверку в других браузерах.

Список использованных источников.

1. Node.js Documentation: SQLite (node:sqlite) [Электронный ресурс]. – URL: https://nodejs.org/docs/latest/api/sqlite.html (на английском языке).

2. Node.js Documentation: Crypto (scrypt, timingSafeEqual) [Электронный ресурс]. – URL: https://nodejs.org/docs/latest/api/crypto.html (на английском языке).

3. SQLite Documentation: CREATE TRIGGER [Электронный ресурс]. – URL: https://www.sqlite.org/lang_createtrigger.html (на английском языке).

4. SQLite Documentation: Partial Indexes [Электронный ресурс]. – URL: https://www.sqlite.org/partialindex.html (на английском языке).

5. MDN Web Docs: HTTP-куки [Электронный ресурс]. – URL: https://developer.mozilla.org/ru/docs/Web/HTTP/Guides/Cookies (на русском языке).

6. MDN Web Docs: Content-Security-Policy [Электронный ресурс]. – URL: https://developer.mozilla.org/ru/docs/Web/HTTP/Guides/CSP (на русском языке).

7. Unsplash License (источник фотографий) [Электронный ресурс]. – URL: https://unsplash.com/license (на английском языке).

Профессиональные термины: транзакция, триггер, состояние гонки, CSRF, частичный уникальный индекс.